Audit de conformité DORA – Banque Ardelle 2026

Digital Operational Resilience Act (DORA)

REGULATION (EU) 2022/2554 OF THE EUROPEAN PARLIAMENT AND OF THE COUNCIL of 14 December 2022 on digital operational resilience for the financial sector and amending Regulations (EC) No 1060/2009, (EU) No 648/2012, (EU) No 600/2014, (EU) No 909/2014 and (EU) 2016/1011

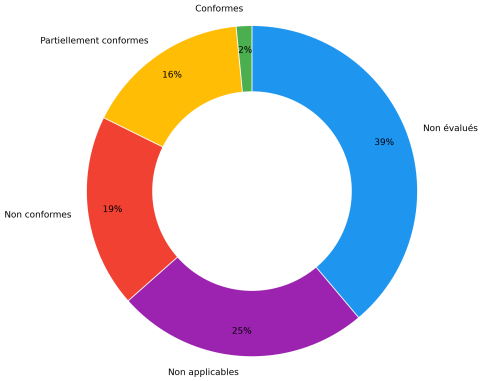
Référence	AUD-DORA-01
Date	28/10/2026
Groupes d'implémentation	Tous
Contributeurs	Auditeur GRC ,

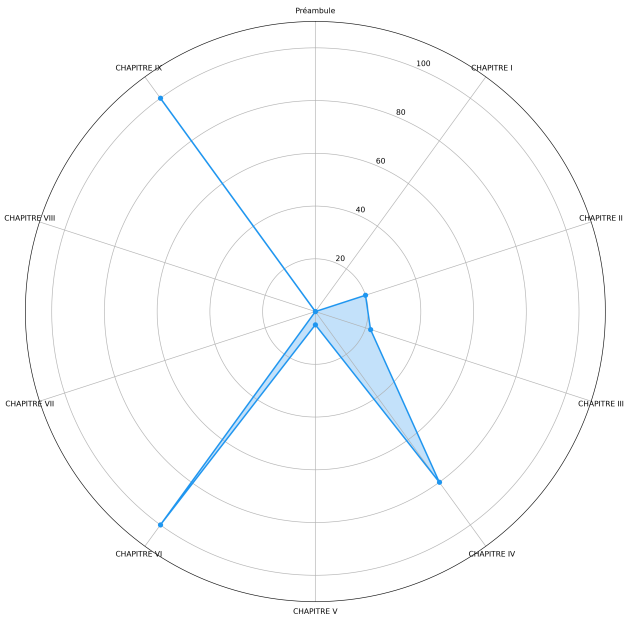
Généré le 2026-10-28 19:21:04 UTC
Identifiant du document 3b5e4e60-4d77-443a-ba75-07a34662e51b

Synthèse managériale

Conformes	Partiellement conformes	Non conformes	Non applicables	Non évaluées
4	42	49	64	101

Compliant on **1.5%** of 260 assessed requirements. 11 applied controls are linked to this audit.





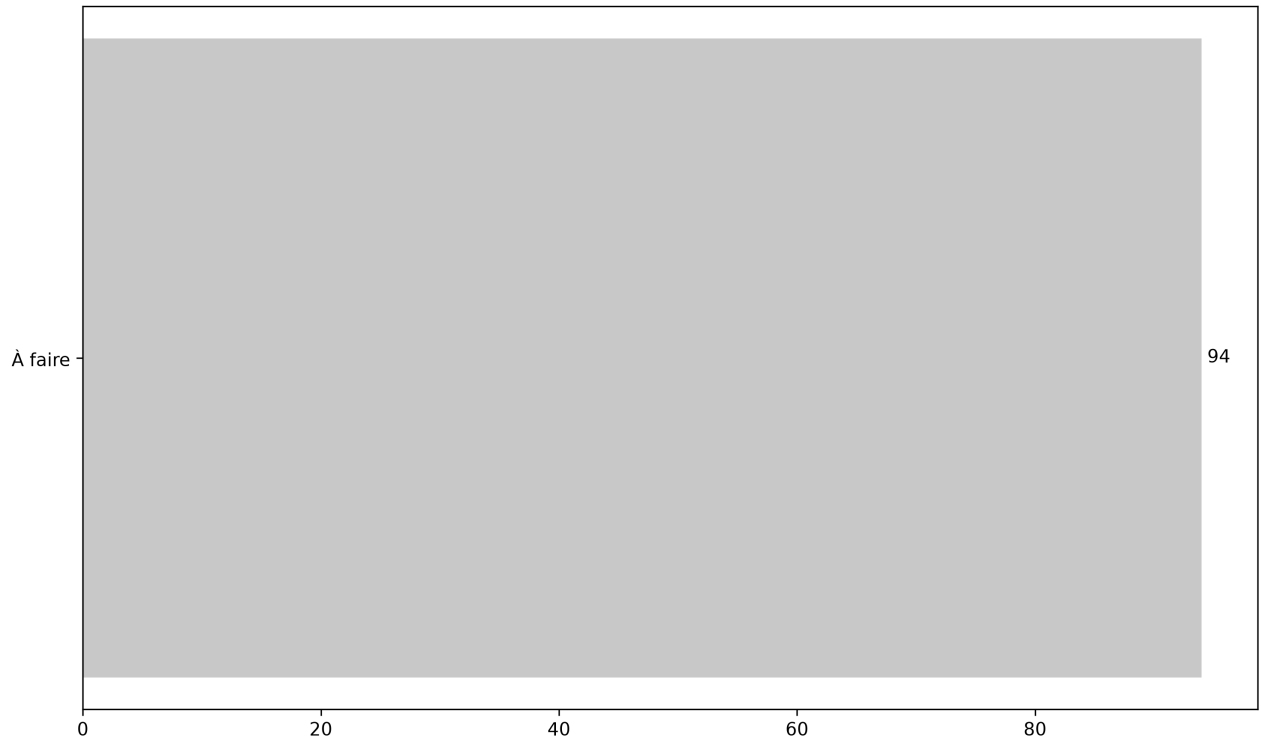
Périmètre

Évaluation de la conformité de la Banque Ardelle au règlement (UE) 2022/2554 (DORA) sur le périmètre des fonctions critiques ou importantes, en préparation du contrôle ACPR du T2 2027. Méthode : revue documentaire et entretiens de cadrage (constats C1 à C10).

Écarts par domaine

Domaine	Constats
Préambule	0
CHAPITRE I	0
CHAPITRE II	101
CHAPITRE III	26
CHAPITRE IV	7
CHAPITRE V	58
CHAPITRE VI	0
CHAPITRE VII	0
CHAPITRE VIII	0
CHAPITRE IX	0

Mesures prioritaires



Mesure	Statut	Catégorie
Aligner la classification des incidents sur les critères réglementaires et tester la notification à l'ACPR	À faire	Processus
Compléter le registre d'informations à 100 % des contrats TIC	À faire	Processus
Faire approuver la politique de gestion du risque TIC par le directoire et instaurer sa revue annuelle	À faire	Politique
Isoler les sauvegardes du core banking (copie hors ligne ou immuable) et tester la restauration	À faire	Technique
Désigner un responsable du suivi des prestataires TIC et adopter une stratégie relative aux prestataires	À faire	Politique
Rattacher le RSSI à la direction des risques (2e ligne)	À faire	Processus
Former les membres du directoire au risque TIC	À faire	Processus

Résultats détaillés

260 exigences évaluables.

5.1 — - Partiellement conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

Les entités financières disposent d'un cadre de gouvernance et de contrôle interne qui garantit une gestion efficace et prudente du risque lié aux TIC, conformément à l'article 6, paragraphe 4, en vue d'atteindre un niveau élevé de résilience opérationnelle numérique.

« Observation »: Un dispositif de gouvernance existe (directoire, comité des risques, trois lignes de maîtrise), mais la fonction de contrôle du risque TIC n'est pas indépendante : le RSSI rend compte au DSI (C2).

« Mesures appliquées »: Rattacher le RSSI à la direction des risques (2e ligne)

5.2 — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité majeure

L'organe de direction de l'entité financière définit, approuve, supervise et est responsable de la mise en œuvre de toutes les dispositions relatives au cadre de gestion du risque lié aux TIC visé à l'article 6, paragraphe 1.

« Observation »: Le directoire n'a ni approuvé ni revu la politique de gestion du risque TIC, datée de 2022 (C1).

« Mesures appliquées »: Faire approuver la politique de gestion du risque TIC par le directoire et instaurer sa revue annuelle

5.2.a — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité majeure

assume la responsabilité ultime de la gestion du risque lié aux TIC de l'entité financière;

« Observation »: Faute d'approbation et de revue de la politique (C1), le directoire n'exerce pas dans les faits sa responsabilité ultime sur le risque TIC.

« Mesures appliquées »: Faire approuver la politique de gestion du risque TIC par le directoire et instaurer sa revue annuelle

5.2.b — - Partiellement conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

met en place des stratégies visant à garantir le maintien de normes élevées en matière de disponibilité, d'authenticité, d'intégrité et de confidentialité des données;

« Observation »: Des mesures existent (authentification forte, SOC 24/7), mais sans stratégie approuvée par le directoire (C1) ; les sauvegardes du core banking ne sont pas isolées (C5).

« Mesures appliquées »: Isoler les sauvegardes du core banking (copie hors ligne ou immuable) et tester la restauration

5.2.c — - Partiellement conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

définit clairement les rôles et les responsabilités pour toutes les fonctions liées aux TIC et met en place des dispositifs de gouvernance appropriés pour assurer une communication, une coopération et une coordination efficaces et en temps utile entre ces fonctions;

« Observation »: Les fonctions TIC sont identifiées (DSI, RSSI, risques, conformité), mais le rattachement du RSSI au DSI crée une confusion entre exploitation et contrôle (C2).

« Mesures appliquées »: Rattacher le RSSI à la direction des risques (2e ligne)

5.2.d — - Non évaluée

Progression: Terminé

assume la responsabilité globale de la définition et de l'approbation de la stratégie de résilience opérationnelle numérique visée à l'article 6, paragraphe 8, y compris la détermination du niveau approprié de tolérance au risque lié aux TIC de l'entité financière, tel que visé à l'article 6, paragraphe 8, point b);

« Observation »: Aucune stratégie de résilience opérationnelle numérique ni niveau de tolérance au risque TIC présentés lors des entretiens. Preuve à demander.

5.2.e — - Partiellement conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

approuve, supervise et examine périodiquement la mise en œuvre de la politique de continuité des activités de TIC de l'entité financière et des plans de réponse et de rétablissement des TIC visés, respectivement, à l'article 11, paragraphes 1 et 3, qui peuvent être adoptés en tant que politique spécifique faisant partie intégrante de la politique globale de continuité des activités et du plan de réponse et de rétablissement de l'entité financière;

« Observation »: Un PCA existe et a été testé en 2024, mais sans le scénario de perte de NovaCore (C7) ; son approbation par le directoire n'est pas démontrée.

« Mesures appliquées »: Étendre le PCA, le BIA et le programme de tests aux FCI, scénario de perte de NovaCore inclus

5.2.f — - Non évaluée

Progression: Terminé

approuve et examine périodiquement les plans internes d'audit des TIC et les audits des TIC de l'entité financière ainsi que les modifications significatives qui y sont apportées;

« Observation »: L'audit interne est actif, mais l'approbation de ses plans d'audit TIC par le directoire n'a pas été vérifiée. Preuve à demander.

5.2.g — - Non évaluée

Progression: Terminé

alloue et réexamine périodiquement le budget approprié pour satisfaire les besoins de l'entité financière en matière de résilience opérationnelle numérique pour tous les types de ressources, y compris les programmes pertinents de sensibilisation à la sécurité des TIC et les formations pertinentes à la résilience opérationnelle numérique visés à l'article 13, paragraphe 6, et les compétences en matière de TIC pour l'ensemble du personnel;

« Observation »: Budget de résilience opérationnelle numérique non examiné. Preuve à demander.

5.2.h — - Non évaluée

Progression: Terminé **Précision du résultat:** Observation / point sensible

approuve et examine périodiquement la politique de l'entité financière concernant les modalités d'utilisation des services TIC fournis par des prestataires tiers de services TIC;

« Observation »: Existence et approbation d'une politique sur les prestataires TIC non vérifiées ; les faiblesses constatées (C8 à C10) laissent penser qu'elle est absente ou non appliquée.

5.2.i — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité majeure

met en place, au niveau de l'entreprise, des canaux de notification lui permettant d'être dûment informé des éléments suivants:

« Observation »: L'audit interne a signalé en 2025 un manque de visibilité sur le risque lié aux prestataires TIC : aucun canal ne remonte cette information au directoire.

« Mesures appliquées »: Désigner un responsable du suivi des prestataires TIC et adopter une stratégie relative aux prestataires

5.2.i.i — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité majeure

des accords conclus avec des prestataires tiers de services TIC sur l'utilisation des services TIC;

« Observation »: Le registre d'informations ne recense qu'environ 60 % des contrats TIC (C8) : le directoire ne peut pas être informé de tous les accords.

« Mesures appliquées »: Compléter le registre d'informations à 100 % des contrats TIC

5.2.i.ii — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité majeure

de tout changement significatif pertinent prévu concernant les prestataires tiers de services TIC;

« Observation »: Faute de canal de remontée (voir 5.2.i), les changements significatifs chez les prestataires ne sont pas portés à la connaissance du directoire.

« Mesures appliquées »: Désigner un responsable du suivi des prestataires TIC et adopter une stratégie relative aux prestataires

5.2.i.iii — - Non évaluée

Progression: Terminé

des incidences potentielles de ces changements sur les fonctions critiques ou importantes faisant l'objet de ces accords, notamment un résumé de l'analyse des risques visant à évaluer les incidences de ces changements, et au minimum des incidents majeurs liés aux TIC et de leur incidence, ainsi que des mesures de réponse, de rétablissement et de correction.

« Observation »: Remontée au directoire des incidents majeurs et de leurs impacts sur les FCI non examinée. Preuve à demander.

5.3 — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité majeure

Les entités financières, autres que les microentreprises, instituent un rôle de suivi des accords conclus avec des prestataires tiers de services TIC sur l'utilisation des services TIC, ou désignent un membre de la direction générale chargé de superviser l'exposition aux risques connexe et la documentation pertinente.

« Observation »: Aucun rôle désigné pour suivre les accords avec les prestataires TIC ; l'audit interne a signalé en 2025 un manque de visibilité sur ce risque.

« Mesures appliquées »: Désigner un responsable du suivi des prestataires TIC et adopter une stratégie relative aux prestataires

5.4 — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité majeure

Les membres de l'organe de direction de l'entité financière maintiennent activement à jour des connaissances et des compétences suffisantes pour comprendre et évaluer le risque lié aux TIC et son incidence sur les opérations de l'entité financière, notamment en suivant régulièrement une formation spécifique proportionnée au risque lié aux TIC géré.

« Observation »: Aucun membre du directoire n'a suivi de formation sur le risque TIC depuis 2024 (C3).

« Mesures appliquées »: Former les membres du directoire au risque TIC

6.1 — - Partiellement conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

Les entités financières disposent d'un cadre de gestion du risque lié aux TIC solide, complet et bien documenté, faisant partie de leur système global de gestion des risques, qui leur permet de parer au risque lié aux TIC de manière rapide, efficiente et exhaustive et de garantir un niveau élevé de résilience opérationnelle numérique.

« Mesures appliquées »: Faire approuver la politique de gestion du risque TIC par le directoire et instaurer sa revue annuelle

6.2 — - Partiellement conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

Le cadre de gestion du risque lié aux TIC englobe au moins les stratégies, les politiques, les procédures, les protocoles et les outils de TIC qui sont nécessaires pour protéger dûment et de manière appropriée tous les actifs informationnels et les actifs de TIC, y compris les logiciels, le matériel informatique, les serveurs, ainsi que toutes les composantes et infrastructures physiques pertinentes, telles que les locaux, centres de données et zones sensibles désignées, afin de garantir que tous les actifs informationnels et actifs de TIC sont correctement protégés contre les risques, y compris les dommages et les accès ou utilisations non autorisés.

« Observation »: Le cadre ne couvre pas tous les actifs : l'inventaire n'atteint qu'environ 85 % des applications, le reste relevant du shadow IT (C4).

« Mesures appliquées »: Compléter l'inventaire des actifs, shadow IT compris

6.3 — - Partiellement conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

Conformément à leur cadre de gestion du risque lié aux TIC, les entités financières réduisent au minimum l'incidence du risque lié aux TIC en déployant des stratégies, des politiques, des procédures, des protocoles et des outils de TIC adéquats. Elles fournissent des informations complètes et actualisées sur le risque lié aux TIC et sur leur cadre de gestion du risque lié aux TIC aux autorités compétentes à leur demande.

« Observation »: Des mesures réduisent le risque (authentification forte, SOC 24/7), mais des lacunes subsistent (sauvegardes non isolées, C5). Capacité à fournir ces informations à l'ACPR non vérifiée.

« Mesures appliquées »: Faire approuver la politique de gestion du risque TIC par le directoire et instaurer sa revue annuelle

6.4 — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité majeure

Les entités financières, autres que les microentreprises, confient la responsabilité de la gestion et de la surveillance du risque lié aux TIC à une fonction de contrôle et garantissent un niveau approprié d'indépendance de cette fonction de contrôle afin d'éviter les conflits d'intérêts. Les entités financières garantissent une séparation et une indépendance adéquates des fonctions de gestion du risque lié aux TIC, des fonctions de contrôle et des fonctions d'audit interne, selon le modèle reposant sur trois lignes de défense ou un modèle de gestion des risques et de contrôle internes.

« Observation »: La fonction de contrôle du risque TIC n'est pas indépendante : le RSSI rend compte au DSI, qui pilote l'exploitation qu'il est censé contrôler (C2).

« Mesures appliquées »: Rattacher le RSSI à la direction des risques (2e ligne)

6.5 — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité majeure

Le cadre de gestion du risque lié aux TIC est documenté et réexaminé au moins une fois par an, ou périodiquement pour les microentreprises, ainsi qu'en cas de survenance d'incidents majeurs liés aux ICT, et conformément aux instructions des autorités de surveillance ou aux conclusions tirées des tests de résilience opérationnelle numérique ou des processus d'audit pertinents. Il est amélioré en permanence sur la base des enseignements tirés de la mise en œuvre et du suivi. Un rapport sur le réexamen du cadre de gestion du risque lié aux TIC est présenté à l'autorité compétente à sa demande.

« Observation »: Le cadre n'a pas été réexaminé depuis 2022, alors qu'un réexamen au moins annuel est exigé (C1).

« Mesures appliquées »: Faire approuver la politique de gestion du risque TIC par le directoire et instaurer sa revue annuelle

6.6 — - Non évaluée

Progression: Terminé

Le cadre de gestion du risque lié aux TIC des entités financières, autres que les microentreprises, fait l'objet d'audits internes réguliers réalisés par des auditeurs conformément au plan d'audit des entités financières. Ces auditeurs possèdent des connaissances, des compétences et une expertise suffisantes en matière de risque lié aux TIC, et font preuve d'une indépendance adéquate. La fréquence et l'objectif des audits des TIC sont proportionnés au risque lié aux TIC de l'entité financière.

« Observation »: L'audit interne a traité le risque TIC en 2025 (prestataires) ; le plan d'audit, la fréquence et les compétences TIC des auditeurs restent à vérifier. Preuve à demander.

6.7 — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

Sur la base des conclusions de l'audit interne, les entités financières mettent en place un processus de suivi formel, comprenant des règles pour la vérification et la correction en temps utile des constatations d'importance critique de l'audit des TIC.

« Observation »: Le constat de l'audit interne de 2025 sur les prestataires TIC n'a pas été corrigé (registre à 60 %, C8 ; aucun rôle de suivi, 5.3) : le suivi des recommandations n'est pas efficace.

« Mesures appliquées »: Faire approuver la politique de gestion du risque TIC par le directoire et instaurer sa revue annuelle

6.8 — - Non évaluée

Progression: Terminé

Le cadre de gestion du risque lié aux TIC comprend une stratégie de résilience opérationnelle numérique qui définit les modalités de mise en œuvre du cadre. À cette fin, la stratégie de résilience opérationnelle numérique précise les méthodes pour parer au risque lié aux TIC et atteindre des objectifs spécifiques en matière de TIC, en:

« Observation »: Aucune stratégie de résilience opérationnelle numérique présentée lors des entretiens (voir 5.2.d). Preuve à demander.

6.8.a — - Non évaluée

Progression: Terminé

expliquant la manière dont le cadre de gestion du risque lié aux TIC soutient la stratégie d'entreprise et les objectifs de l'entité financière;

« Observation »: Aucune stratégie de résilience opérationnelle numérique présentée lors des entretiens (voir 5.2.d). Preuve à demander.

6.8.b — - Non évaluée

Progression: Terminé

déterminant le niveau de tolérance au risque lié aux TIC, en fonction de l'appétit pour le risque de l'entité financière, et en analysant la tolérance à l'incidence des dysfonctionnements des TIC;

« Observation »: Aucune stratégie de résilience opérationnelle numérique présentée lors des entretiens (voir 5.2.d). Preuve à demander.

6.8.c — - Non évaluée

Progression: Terminé

définissant des objectifs clairs en matière de sécurité de l'information, y compris des indicateurs de performance clés et des indicateurs de risque clés;

« Observation »: Aucune stratégie de résilience opérationnelle numérique présentée lors des entretiens (voir 5.2.d). Preuve à demander.

6.8.d — - Non évaluée

Progression: Terminé

décrivant l'architecture des TIC de référence et les changements nécessaires pour atteindre des objectifs spécifiques de l'entité financière;

« Observation »: Aucune stratégie de résilience opérationnelle numérique présentée lors des entretiens (voir 5.2.d). Preuve à demander.

6.8.e — - Non évaluée

Progression: Terminé

présentant les différents mécanismes mis en place pour détecter et prévenir les incidents liés aux TIC, ainsi que pour se protéger contre leurs effets;

« Observation »: Aucune stratégie de résilience opérationnelle numérique présentée lors des entretiens (voir 5.2.d). Preuve à demander.

6.8.f — - Non évaluée

Progression: Terminé

déterminant la situation actuelle en matière de résilience opérationnelle numérique sur la base du nombre d'incidents majeurs liés aux TIC signalés et de l'efficacité des mesures de prévention;

« Observation »: Aucune stratégie de résilience opérationnelle numérique présentée lors des entretiens (voir 5.2.d). Preuve à demander.

6.8.g — - Non évaluée

Progression: Terminé

mettant en œuvre des tests de résilience opérationnelle numérique, conformément au chapitre IV du présent règlement;

« Observation »: Aucune stratégie de résilience opérationnelle numérique présentée lors des entretiens (voir 5.2.d). Preuve à demander.

6.8.h — - Non évaluée

Progression: Terminé

définissant une stratégie de communication en cas d'incidents liés aux TIC qui doivent être divulgués en vertu de l'article 14.

« Observation »: Aucune stratégie de résilience opérationnelle numérique présentée lors des entretiens (voir 5.2.d). Preuve à demander.

6.9 — - Non applicable

Progression: Terminé **Précision du résultat:** Opportunité d'amélioration

Les entités financières peuvent, dans le contexte de la stratégie de résilience opérationnelle numérique visée au paragraphe 8, définir une stratégie globale multi-fournisseurs en matière de TIC au niveau du groupe ou de l'entité, qui met en évidence les principales relations de dépendance à l'égard des prestataires tiers de services TIC et expose les raisons qui sous-tendent la combinaison de prestataires tiers de services TIC choisis.

« Observation »: Faculté, et non obligation (« peuvent »). Recommandé au vu de la dépendance à Stratus Cloud et à NovaCore.

6.10 — - Non applicable

Progression: Terminé

Les entités financières peuvent, conformément au droit de l'Union et au droit sectoriel national, externaliser les tâches de vérification du respect des exigences en matière de gestion du risque lié aux TIC à des entreprises intra-groupe ou externes. Dans le cas d'une telle externalisation, l'entité financière reste pleinement responsable de la vérification du respect des exigences en matière de gestion du risque lié aux TIC.

« Observation »: Faculté non utilisée : la banque n'a pas externalisé la vérification de sa conformité.

- — - Non évaluée

Progression: Terminé

Afin d'atténuer et de gérer le risque lié aux TIC, les entités financières utilisent et tiennent à jour des systèmes, protocoles et outils de TIC qui sont:

« Observation »: Aucune information sur la capacité, la fiabilité et la résilience des systèmes TIC (dimensionnement, tests de charge). Preuve non fournie à la date de clôture.

7.a — - Non évaluée

Progression: Terminé

adaptés à l'ampleur des opérations qui sous-tendent l'exercice de leurs activités, conformément au principe de proportionnalité visé à l'article 4;

« Observation »: Aucune information sur la capacité, la fiabilité et la résilience des systèmes TIC (dimensionnement, tests de charge). Preuve non fournie à la date de clôture.

7.b — - Non évaluée

Progression: Terminé

fiables;

« Observation »: Aucune information sur la capacité, la fiabilité et la résilience des systèmes TIC (dimensionnement, tests de charge). Preuve non fournie à la date de clôture.

7.c — - Non évaluée

Progression: Terminé

équipés d'une capacité suffisante pour traiter avec exactitude les données nécessaires à l'exécution des activités et à la fourniture des services en temps utile, et pour faire face aux pics de volume d'ordres, de messages ou de transactions, selon les besoins, y compris lorsque de nouvelles technologies sont mises en place;

« Observation »: Aucune information sur la capacité, la fiabilité et la résilience des systèmes TIC (dimensionnement, tests de charge). Preuve non fournie à la date de clôture.

7.d — - Non évaluée

Progression: Terminé

suffisamment résilients sur le plan technologique pour répondre de manière adéquate aux besoins supplémentaires de traitement de l'information qui apparaissent en situation de tensions sur les marchés ou dans d'autres situations défavorables.

« Observation »: Aucune information sur la capacité, la fiabilité et la résilience des systèmes TIC (dimensionnement, tests de charge). Preuve non fournie à la date de clôture.

8.1 — - Partiellement conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

Aux fins du cadre de gestion du risque lié aux TIC visé à l'article 6, paragraphe 1, les entités financières identifient, classent et documentent de manière adéquate toutes les fonctions «métiers», tous les rôles et toutes les responsabilités s'appuyant sur les TIC, les actifs informationnels et les actifs de TIC qui soutiennent ces fonctions, ainsi que leurs rôles et dépendances en ce qui concerne le risque lié aux TIC. Les entités financières examinent si nécessaire, et au moins une fois par an, le caractère adéquat de cette classification et de toute documentation pertinente.

« Observation »: Les FCI sont identifiées, mais l'inventaire des actifs qui les soutiennent est incomplet (C4) et sa revue annuelle n'est pas démontrée.

« Mesures appliquées »: Compléter l'inventaire des actifs, shadow IT compris

8.2 — - Non évaluée

Progression: Terminé **Précision du résultat:** Observation / point sensible

Les entités financières identifient, de manière continue, toutes les sources de risque lié aux TIC, en particulier l'exposition au risque vis-à-vis d'autres entités financières et émanant de celles-ci, et évaluent les cybermenaces et les vulnérabilités des TIC qui concernent leurs fonctions «métiers» s'appuyant sur les TIC, leurs actifs informationnels et leurs actifs de TIC. Les entités financières examinent régulièrement, et au moins une fois par an, les scénarios de risque qui ont des incidences sur elles.

« Observation »: Aucune analyse de risques ni revue annuelle des scénarios présentée ; l'analyse EBIOS RM de la mission semble être la première.

8.3 — - Non évaluée

Progression: Terminé

Les entités financières, autres que les microentreprises, procèdent à une évaluation des risques à chaque modification importante de l'infrastructure du réseau et du système d'information, des processus ou des procédures, qui affecte leurs fonctions «métiers» s'appuyant sur les TIC, leurs actifs informationnels ou leurs actifs de TIC.

« Observation »: Évaluation des risques lors des changements importants non examinée. Preuve non fournie à la date de clôture.

8.4 — - Partiellement conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

Les entités financières identifient tous les actifs informationnels et actifs de TIC, y compris ceux situés sur des sites extérieurs, les ressources du réseau et les équipements matériels, et répertorient ceux considérés comme critiques. Elles répertorient la configuration des actifs informationnels et des actifs de TIC et les liens et interdépendances entre les différents actifs informationnels et actifs de TIC.

« Observation »: Environ 15 % des applications échappent à l'inventaire (shadow IT, C4) ; les interdépendances n'étaient pas cartographiées avant la mission.

« Mesures appliquées »: Compléter l'inventaire des actifs, shadow IT compris

8.5 — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité majeure

Les entités financières identifient et documentent tous les processus qui dépendent de prestataires tiers de services TIC, et identifient les interconnexions avec des prestataires tiers de services TIC qui fournissent des services qui soutiennent des fonctions critiques ou importantes.

« Observation »: Les processus dépendant de prestataires TIC ne sont pas tous documentés : le registre d'informations ne couvre qu'environ 60 % des contrats (C8).

« Mesures appliquées »: Compléter le registre d'informations à 100 % des contrats TIC

8.6 — - Partiellement conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

Aux fins des paragraphes 1, 4 et 5, les entités financières tiennent des inventaires pertinents et les mettent à jour périodiquement et chaque fois qu'a lieu une modification importante visée au paragraphe 3.

« Observation »: Les inventaires existent mais sont incomplets et ne sont pas tenus à jour (C4).

« Mesures appliquées »: Compléter l'inventaire des actifs, shadow IT compris

8.7 — - Non évaluée

Progression: Terminé

Les entités financières, autres que les microentreprises, procèdent régulièrement, et au moins une fois par an, à une évaluation spécifique du risque lié aux TIC sur tous les systèmes de TIC hérités et, dans tous les cas, avant et après la connexion de technologies, d'applications ou de systèmes.

« Observation »: Évaluation des systèmes hérités non examinée. Preuve non fournie à la date de clôture.

9.1 — - Partiellement conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

Aux fins de la protection adéquate des systèmes de TIC et en vue d'organiser les mesures de réponse, les entités financières assurent un suivi et un contrôle permanents de la sécurité et du fonctionnement des systèmes et outils de TIC et réduisent au minimum l'incidence du risque lié aux TIC sur les systèmes de TIC par le déploiement d'outils, de stratégies et de procédures appropriés en matière de sécurité des TIC.

« Observation »: Un SOC externalisé assure une supervision 24/7, mais le shadow IT (environ 15 % des applications, C4) échappe à ce suivi.

« Mesures appliquées »: Compléter l'inventaire des actifs, shadow IT compris

9.2 — - Partiellement conforme

Progression: Terminé

Les entités financières conçoivent, acquièrent et mettent en œuvre des stratégies, des politiques, des procédures, des protocoles et des outils de sécurité de TIC qui visent à garantir la résilience, la continuité et la disponibilité des systèmes de TIC, en particulier ceux qui soutiennent des fonctions critiques ou importantes, et à maintenir des normes élevées en matière de disponibilité, d'authenticité, d'intégrité et de confidentialité des données, que ce soit au repos, en cours d'utilisation ou en transit.

« Observation »: Des mesures existent (authentification forte, SOC 24/7), mais sans stratégie approuvée par le directoire (C1) ; sauvegardes non isolées (C5).

« Mesures appliquées »: Faire approuver la politique de gestion du risque TIC par le directoire et instaurer sa revue annuelle

9.3 — - Partiellement conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

Pour atteindre les objectifs visés au paragraphe 2, les entités financières utilisent des solutions et des processus de TIC qui sont appropriés conformément à l'article 4. Ces solutions et processus de TIC:

« Observation »: Les solutions en place couvrent une partie des objectifs ; voir les points 9.3.b et 9.3.c.

« Mesures appliquées »: Isoler les sauvegardes du core banking (copie hors ligne ou immuable) et tester la restauration

9.3.a — - Non évaluée

Progression: Terminé

garantissent la sécurité des moyens de transfert de données;

« Observation »: Sécurité des transferts de données (chiffrement des flux) non examinée. Preuve non fournie à la date de clôture.

9.3.b — - Partiellement conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

réduisent au minimum le risque de corruption ou de perte de données, d'accès non autorisé et de défauts techniques susceptibles d'entraver les activités;

« Observation »: L'authentification forte limite les accès non autorisés, mais les sauvegardes non isolées exposent à une perte de données en cas de rançongiciel (C5).

« Mesures appliquées »: Isoler les sauvegardes du core banking (copie hors ligne ou immuable) et tester la restauration

9.3.c — - Partiellement conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

empêchent le manque de disponibilité, les atteintes à l'authenticité et à l'intégrité, les violations de la confidentialité et la perte de données;

« Observation »: Même constat que 9.3.b : la perte de données n'est pas prévenue faute de sauvegardes isolées (C5).

« Mesures appliquées »: Isoler les sauvegardes du core banking (copie hors ligne ou immuable) et tester la restauration

9.3.d — - Non évaluée

Progression: Terminé

garantissent que les données sont protégées contre les risques découlant de la gestion des données, y compris une mauvaise administration, les risques relatifs au traitement et l'erreur humaine.

« Observation »: Gestion des risques liés à l'administration des données et à l'erreur humaine non examinée. Preuve non fournie à la date de clôture.

9.4 — - Non applicable

Progression: Terminé

Aux fins du cadre de gestion du risque lié aux TIC visé à l'article 6, paragraphe 1, les entités financières:

« Observation »: Phrase d'introduction : l'évaluation porte sur les points a à f.

9.4.a — - Partiellement conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

élaborent et documentent une politique de sécurité de l'information qui définit des règles visant à protéger la disponibilité, l'authenticité, l'intégrité et la confidentialité des données, des actifs informationnels et des actifs de TIC, y compris ceux de leurs clients, le cas échéant;

« Observation »: Une politique existe, mais elle date de 2022 et n'a été ni revue ni approuvée par le directoire (C1).

« Mesures appliquées »: Faire approuver la politique de gestion du risque TIC par le directoire et instaurer sa revue annuelle

9.4.b — - Non évaluée

Progression: Terminé

instaurent, selon une approche fondée sur les risques, une gestion solide des réseaux et des infrastructures en recourant aux techniques, aux méthodes et aux protocoles appropriés, qui peuvent inclure la mise en œuvre de mécanismes automatisés pour isoler les actifs informationnels affectés en cas de cyberattaques;

« Observation »: Gestion des réseaux et des infrastructures non examinée. Preuve non fournie à la date de clôture.

9.4.c — - Non évaluée

Progression: Terminé **Précision du résultat:** Observation / point sensible

mettent en œuvre des politiques qui limitent l'accès physique ou logique aux actifs informationnels et aux actifs de TIC, à ce qui est nécessaire pour les fonctions et les activités légitimes et approuvées uniquement, et définissent à cette fin un ensemble de politiques, de procédures et de contrôles qui portent sur les droits d'accès et veillent à leur bonne administration;

« Observation »: Politique de gestion des droits d'accès non examinée ; point de vigilance : les accès privilégiés étendus de Sentinelle SOC.

9.4.d — - Conforme

Progression: Terminé **Précision du résultat:** Observation / point sensible

mettent en œuvre des politiques et des protocoles pour des mécanismes d'authentification forte, fondés sur des normes pertinentes et des systèmes de contrôle spécifiques, et des mesures de protection des clés de chiffrement par lesquelles les données sont chiffrées sur la base des résultats des processus approuvés de classification des données et d'évaluation du risque lié aux TIC;

« Observation »: Authentification forte en place pour tous les clients et HSM pour les paiements ; à confirmer pour les accès des administrateurs et des prestataires (accès distant de Kumo Digital depuis le Maroc).

9.4.e — - Non évaluée

Progression: Terminé

mettent en œuvre des politiques, des procédures et des contrôles documentés pour la gestion des changements dans les TIC, y compris les changements apportés aux logiciels, au matériel, aux composants de micrologiciels, aux systèmes ou aux paramètres de sécurité, qui sont fondés sur une approche d'évaluation des risques et font partie intégrante du processus global de gestion des changements de l'entité financière, afin de garantir que tous les changements apportés aux systèmes de TIC sont consignés, testés, évalués, approuvés, mis en œuvre et vérifiés de manière contrôlée;

« Observation »: Processus de gestion des changements non examiné. Preuve non fournie à la date de clôture.

9.4.f — - Non évaluée

Progression: Terminé

disposent de stratégies documentées appropriées et globales en matière de correctifs et de mises à jour.

« Observation »: Stratégie de gestion des correctifs non examinée. Preuve non fournie à la date de clôture.

- — - Non évaluée

Progression: Terminé **Précision du résultat:** Observation / point sensible

Aux fins du premier alinéa, point b), les entités financières conçoivent l'infrastructure de connexion au réseau de manière à permettre une déconnexion instantanée ou segmentée afin de réduire au minimum la contagion et de la prévenir, en particulier pour les processus financiers interconnectés.

« Observation »: Segmentation du réseau non examinée ; point de vigilance au vu du scénario de propagation depuis l'accès de Kumo Digital.

- — - Non évaluée

Progression: Terminé

Aux fins du premier alinéa, point e), le processus de gestion des changements dans les TIC est approuvé par la structure hiérarchique appropriée et comporte des protocoles spécifiques.

« Observation »: Approbation du processus de gestion des changements non examinée. Preuve non fournie à la date de clôture.

10.1 — - Partiellement conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

Les entités financières mettent en place des mécanismes permettant de détecter rapidement les activités anormales, conformément à l'article 17, y compris les problèmes de performance des réseaux de TIC et les incidents liés aux TIC, ainsi que de repérer les points uniques de défaillance potentiellement significatifs.

« Observation »: Le SOC 24/7 détecte les activités anormales, mais les points uniques de défaillance (NovaCore, Stratus Cloud) n'ont pas été identifiés (C10).

« Mesures appliquées »: Rédiger les stratégies de sortie NovaCore et Stratus Cloud et analyser le risque de concentration

- — - Non évaluée

Progression: Terminé

Tous les mécanismes de détection visés au premier alinéa sont régulièrement testés conformément à l'article 25.

« Observation »: Standard

10.2 — - Non évaluée

Progression: Terminé

Les mécanismes de détection visés au paragraphe 1 permettent la mise en place de plusieurs niveaux de contrôle, définissent des seuils d'alerte et des critères de déclenchement et de lancement des processus de réponse en cas d'incident lié aux TIC, y compris des mécanismes d'alerte automatique destinés au personnel compétent chargé de la réponse aux incidents liés aux TIC.

« Observation »: Seuils d'alerte et critères de déclenchement du SOC non examinés. Preuve non fournie à la date de clôture.

10.3 — - Conforme

Progression: Terminé

Les entités financières consacrent des ressources et des capacités suffisantes pour surveiller l'activité des utilisateurs, l'apparition d'anomalies liées aux TIC et d'incidents liés aux TIC, en particulier les cyberattaques.

« Observation »: Ressources de surveillance dédiées : SOC externalisé opérationnel 24/7.

10.4 — - Non applicable

Progression: Terminé

Les prestataires de services de communication de données disposent en outre de systèmes capables de vérifier efficacement l'exhaustivité des déclarations de transactions, de repérer les omissions et les erreurs manifestes et de demander une nouvelle transmission de ces déclarations.

« Observation »: Vise les prestataires de services de communication de données, pas les banques.

11.1 — - Partiellement conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

Aux fins du cadre de gestion du risque lié aux TIC visé à l'article 6, paragraphe 1, et sur la base des exigences en matière d'identification énoncées à l'article 8, les entités financières se dotent d'une politique de continuité des activités de TIC complète, qui peut être adoptée en tant que politique spécifique, et qui forme une partie intégrante de leur politique globale de continuité des activités.

« Observation »: Un PCA existe, mais il ne couvre pas la perte de NovaCore (C7).

« Mesures appliquées »: Étendre le PCA, le BIA et le programme de tests aux FCI, scénario de perte de NovaCore inclus

11.2 — - Partiellement conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

Les entités financières mettent en œuvre la politique de continuité des activités de TIC au moyen de dispositifs, de plans, de procédures et de mécanismes spécifiques, appropriés et documentés visant à:

« Observation »: Dispositifs de continuité en place mais incomplets (voir 11.2.a à e).

« Mesures appliquées »: Étendre le PCA, le BIA et le programme de tests aux FCI, scénario de perte de NovaCore inclus

11.2.a — - Partiellement conforme

Progression: Terminé **Précision du résultat:** Non-conformité majeure

garantir la continuité des fonctions critiques ou importantes de l'entité financière;

« Observation »: La continuité de FCI-01 n'est pas garantie en cas de défaillance de NovaCore : ni scénario PCA (C7), ni stratégie de sortie (C10).

« Mesures appliquées »: Rédiger les stratégies de sortie NovaCore et Stratus Cloud et analyser le risque de concentration

11.2.b — - Partiellement conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

répondre aux incidents liés aux TIC et les résoudre rapidement, dûment et efficacement de manière à limiter les dommages et à donner la priorité à la reprise des activités et aux mesures de rétablissement;

« Observation »: Réponse aux incidents assurée par le SOC, mais processus antérieur à DORA (C6).

« Mesures appliquées »: Aligner la classification des incidents sur les critères réglementaires et tester la notification à l'ACPR

11.2.c — - Non évaluée

Progression: Terminé

activer, sans retard, des plans spécifiques permettant de déployer des mesures, des processus et des technologies d'endiguement adaptés à chaque type d'incident lié aux TIC et de prévenir tout dommage supplémentaire, ainsi que des procédures sur mesure de réponse et de rétablissement, définies conformément à l'article 12;

« Observation »: Standard

11.2.d — - Non évaluée

Progression: Terminé

estimer les incidences, les dommages et les pertes préliminaires;

« Observation »: Standard

11.2.e — - Partiellement conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

définir des mesures de communication et de gestion des crises qui garantissent la transmission d'informations actualisées à tous les membres du personnel interne et à toutes les parties prenantes externes concernés, conformément à l'article 14, et leur déclaration aux autorités compétentes, conformément à l'article 19.

« Observation »: Communication de crise non examinée ; la chaîne de notification à l'ACPR n'a jamais été testée (C6).

« Mesures appliquées »: Aligner la classification des incidents sur les critères réglementaires et tester la notification à l'ACPR

11.3 — - Non évaluée

Progression: Terminé

Aux fins du cadre de gestion du risque lié aux TIC visé à l'article 6, paragraphe 1, les entités financières mettent en œuvre des plans de réponse et de rétablissement des TIC qui, dans le cas des entités financières, autres que les microentreprises, font l'objet de revues indépendantes de l'audit interne.

« Observation »: Standard

11.4 — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité majeure

Les entités financières mettent en place, maintiennent et testent périodiquement des plans de continuité des activités de TIC appropriés, notamment en ce qui concerne les fonctions critiques ou importantes externalisées ou sous-traitées dans le cadre d'accords avec des prestataires tiers de services TIC.

« Observation »: Dernier test du PCA en 2024, sans la FCI externalisée chez NovaCore (C7).

« Mesures appliquées »: Étendre le PCA, le BIA et le programme de tests aux FCI, scénario de perte de NovaCore inclus

11.5 — - Partiellement conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

Dans le cadre de la politique globale de continuité des activités, les entités financières procèdent à une analyse des incidences sur les activités de leurs expositions à de graves perturbations de leurs activités. Dans le cadre de cette analyse, les entités financières évaluent l'incidence potentielle de graves perturbations de leurs activités au moyen de critères quantitatifs et qualitatifs, à l'aide de données internes et externes et d'une analyse de scénarios, le cas échéant. L'analyse des incidences sur les activités tient compte du caractère critique des fonctions «métiers», des processus de soutien, des dépendances de tiers et des actifs informationnels identifiés et cartographiés, ainsi que de leurs interdépendances. Les entités financières veillent à ce que les actifs de TIC et les services TIC soient conçus et utilisés dans le respect total de l'analyse des incidences sur les activités, en particulier en garantissant de manière adéquate la redondance de toutes les composantes critiques.

« Observation »: Durées maximales d'interruption définies pour les FCI, mais pas de BIA formalisé couvrant les dépendances aux tiers ; RTO et RPO non validés par les métiers.

« Mesures appliquées »: Étendre le PCA, le BIA et le programme de tests aux FCI, scénario de perte de NovaCore inclus

11.6.a — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité majeure

testent les plans de continuité des activités de TIC et les plans de réponse et de rétablissement des TIC concernant les systèmes de TIC soutenant toutes les fonctions au moins une fois par an ainsi qu'en cas de modifications substantielles apportées aux systèmes de TIC qui soutiennent des fonctions critiques ou importantes;

« Observation »: Aucun test annuel : le dernier date de 2024 (C7).

« Mesures appliquées »: Étendre le PCA, le BIA et le programme de tests aux FCI, scénario de perte de NovaCore inclus

11.6.b — - Non évaluée

Progression: Terminé

testent les plans de communication en situation de crise établis conformément à l'article 14.

« Observation »: Standard

- — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

Aux fins du premier alinéa, point a), les entités financières, autres que les microentreprises, incluent dans les plans de test des scénarios de cyberattaques et de basculement entre l'infrastructure de TIC principale et la capacité redondante, les sauvegardes et les installations redondantes nécessaires pour satisfaire aux obligations énoncées à l'article 12.

« Observation »: Le test de 2024 n'incluait ni la perte de NovaCore, ni un basculement démontré vers les capacités redondantes (C7).

« Mesures appliquées »: Étendre le PCA, le BIA et le programme de tests aux FCI, scénario de perte de NovaCore inclus

- — - Non évaluée

Progression: Terminé

Les entités financières réexaminent régulièrement leur politique de continuité des activités de TIC et leurs plans de réponse et de rétablissement des TIC en tenant compte des résultats des tests effectués conformément au premier alinéa et des recommandations découlant des contrôles d'audit ou des examens des autorités de surveillance.

« Observation »: Standard

11.7 — - Non évaluée

Progression: Terminé

Les entités financières, autres que les microentreprises, disposent d'une fonction de gestion de crise qui, en cas d'activation de leurs plans de continuité des activités de TIC ou de leurs plans de réponse et de rétablissement des TIC, définit, entre autres, des procédures claires pour gérer les communications internes et externes en situation de crise, conformément à l'article 14.

« Observation »: Standard

11.8 — - Non évaluée

Progression: Terminé

Les entités financières tiennent un registre, facile d'accès, des activités avant et pendant les perturbations lorsque leurs plans de continuité des activités de TIC et leurs plans de réponse et de rétablissement des TIC sont activés.

« Observation »: Standard

11.9 — - Non évaluée

Progression: Terminé

Les dépositaires centraux de titres fournissent aux autorités compétentes des copies des résultats des tests de continuité des activités de TIC ou d'exercices similaires.

« Observation »: Vise les dépositaires centraux de titres.

11.10 — - Non évaluée

Progression: Terminé

Les entités financières, autres que les microentreprises, communiquent aux autorités compétentes, à leur demande, une estimation des coûts et pertes annuels agrégés occasionnés par des incidents majeurs liés aux TIC.

« Observation »: Standard

12.1 — - Partiellement conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

Dans le but de veiller à la restauration des systèmes et des données des TIC en limitant au maximum la durée d'indisponibilité, les perturbations et les pertes, aux fins de leur cadre de gestion du risque lié aux TIC, les entités financières définissent et documentent:

« Observation »: Des sauvegardes existent, mais leur politique n'a pas été présentée (voir 12.1.a).

« Mesures appliquées »: Isoler les sauvegardes du core banking (copie hors ligne ou immuable) et tester la restauration

12.1.a — - Non évaluée

Progression: Terminé

des politiques et procédures de sauvegarde qui précisent la portée des données concernées par la sauvegarde et la fréquence minimale de celle-ci, en fonction de la criticité des informations ou du niveau de confidentialité des données;

« Observation »: Standard

12.1.b — - Non évaluée

Progression: Terminé

des procédures et méthodes de restauration et de rétablissement.

« Observation »: Standard

12.2 — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité majeure

Les entités financières mettent en place des systèmes de sauvegarde qui peuvent être activés conformément aux politiques et procédures de sauvegarde, ainsi qu'aux procédures et méthodes de restauration et de rétablissement. L'activation de systèmes de sauvegarde ne compromet pas la sécurité du réseau et des systèmes d'information ni la disponibilité, l'authenticité, l'intégrité ou la confidentialité des données. Des tests des procédures de sauvegarde et des procédures et méthodes de restauration et de rétablissement sont effectués périodiquement.

« Observation »: Les sauvegardes du core banking ne sont pas isolées du réseau de production : un rançongiciel les chiffrerait en même temps que la production (C5).

« Mesures appliquées »: Isoler les sauvegardes du core banking (copie hors ligne ou immuable) et tester la restauration

12.3 — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité majeure

Lorsqu'elles restaurent des données de sauvegarde à l'aide de leurs propres systèmes, les entités financières utilisent des systèmes de TIC qui sont séparés physiquement et logiquement du système de TIC source. Les systèmes de TIC sont protégés de manière sécurisée contre tout accès non autorisé ou toute corruption des TIC et permettent la restauration en temps utile des services grâce à la sauvegarde des données et des systèmes si nécessaire.

« Observation »: La restauration ne repose pas sur des systèmes séparés physiquement et logiquement du système source (C5).

« Mesures appliquées »: Isoler les sauvegardes du core banking (copie hors ligne ou immuable) et tester la restauration

- — - Non applicable

Progression: Terminé

Dans le cas des contreparties centrales, les plans de rétablissement favorisent la reprise de toutes les transactions qui étaient en cours au moment de la perturbation, pour permettre aux contreparties centrales de continuer à fonctionner avec précision et d'achever le règlement à la date programmée.

« Observation »: Vise les contreparties centrales.

- — - Non applicable

Progression: Terminé

Les prestataires de services de communication de données maintiennent en outre des ressources adéquates et possèdent des dispositifs de sauvegarde et de restauration afin d'offrir et de maintenir leurs services à tout moment.

« Observation »: Vise ces prestataires, pas les banques.

12.4 — - Conforme

Progression: Terminé **Précision du résultat:** Observation / point sensible

Les entités financières, autres que les microentreprises, maintiennent des capacités en matière de TIC redondantes dotées de ressources, de capacités et de fonctions adéquates pour répondre à leurs besoins. Les microentreprises évaluent la nécessité de maintenir ces capacités en matière de TIC redondantes en se fondant sur leur profil de risque.

« Observation »: Deux datacenters (Lyon et Villeurbanne) ; point de vigilance : leur proximité expose aux mêmes risques régionaux, et la redondance de NovaCore n'est pas démontrée.

12.5 — - Non applicable

Progression: Terminé

Les dépositaires centraux de titres maintiennent au moins un site de traitement secondaire doté de ressources, de capacités, de fonctions et d'effectifs adéquats pour répondre à leurs besoins.

« Observation »: Vise les dépositaires centraux de titres.

12.5.a — - Non applicable

Progression: Terminé

est situé à une certaine distance géographique du site de traitement primaire afin de veiller à ce qu'il présente un profil de risque distinct et d'éviter qu'il ne soit affecté par l'événement qui a touché le site primaire;

« Observation »: Vise les dépositaires centraux de titres.

12.5.b — - Non applicable

Progression: Terminé

est capable d'assurer la continuité des fonctions critiques ou importantes de la même manière que le site primaire, ou de fournir le niveau de services dont l'entité financière a besoin pour effectuer ses opérations critiques dans le cadre des objectifs de rétablissement;

« Observation »: Vise les dépositaires centraux de titres.

12.5.c — - Non applicable

Progression: Terminé

est immédiatement accessible au personnel de l'entité financière afin d'assurer la continuité des fonctions critiques ou importantes en cas d'indisponibilité du site de traitement primaire.

« Observation »: Vise les dépositaires centraux de titres.

12.6 — - Partiellement conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

Lorsqu'elles déterminent les objectifs en matière de délai de rétablissement et de point de rétablissement pour chaque fonction, les entités financières tiennent compte du caractère critique ou important de la fonction et des effets globaux potentiels sur l'efficience du marché. Ces objectifs temporels permettent d'assurer, dans des scénarios extrêmes, le respect des niveaux de service convenus.

« Observation »: Durées maximales d'interruption fixées selon la criticité des FCI ; RTO et RPO non formalisés ni validés par les métiers.

« Mesures appliquées »: Étendre le PCA, le BIA et le programme de tests aux FCI, scénario de perte de NovaCore inclus

12.7 — - Non évaluée

Progression: Terminé

Lorsqu'elles opèrent un rétablissement à la suite d'un incident lié aux TIC, les entités financières effectuent les contrôles nécessaires, y compris tout contrôle multiple et rapprochement, afin de garantir le niveau d'intégrité des données le plus haut possible. Ces contrôles sont également effectués lors de la reconstitution des données provenant de parties prenantes externes, afin que toutes les données soient cohérentes entre les systèmes.

« Observation »: Standard

13.1 — - Conforme

Progression: Terminé

Les entités financières disposent de capacités et d'effectifs pour recueillir des informations sur les vulnérabilités et les cybermenaces, et sur les incidents liés aux TIC, en particulier les cyberattaques, et analyser leurs incidences probables sur leur résilience opérationnelle numérique.

« Observation »: Le SOC 24/7 collecte et analyse les incidents ; tests d'intrusion annuels sur l'application mobile.

13.2 — - Non évaluée

Progression: Terminé

Les entités financières réalisent des examens post-incident lié aux TIC après qu'un incident majeur lié aux TIC a perturbé leurs activités principales, afin d'analyser les causes de la perturbation et de déterminer les améliorations à apporter aux opérations de TIC ou dans le cadre de la politique de continuité des activités de TIC visée à l'article 11.

« Observation »: Standard

- — - Non évaluée

Progression: Terminé

Les entités financières, autres que les microentreprises, communiquent, sur demande, aux autorités compétentes les changements qui ont été apportés à la suite des examens post-incident lié aux TIC visés au premier alinéa.

« Observation »: Standard

- — - Non évaluée

Progression: Terminé

Les examens post-incident lié aux TIC visés au premier alinéa consistent à déterminer si les procédures établies ont été suivies et si les mesures prises ont été efficaces, notamment en ce qui concerne:

« Observation »: Standard

13.2.a — - Non évaluée

Progression: Terminé

la célérité de la réponse aux alertes de sécurité et de l'évaluation des effets associés aux incidents liés aux TIC et de leur gravité;

« Observation »: Standard

13.2.b — - Non évaluée

Progression: Terminé

la qualité et la rapidité de l'analyse technico-légale, le cas échéant;

« Observation »: Standard

13.2.c — - Non évaluée

Progression: Terminé

l'efficacité de la remontée des incidents au sein de l'entité financière;

« Observation »: Standard

13.2.d — - Non évaluée

Progression: Terminé

l'efficacité de la communication interne et externe.

« Observation »: Standard

13.3 — - Non évaluée

Progression: Terminé

Les enseignements tirés des tests de résilience opérationnelle numérique effectués conformément aux articles 26 et 27 et des incidents liés aux TIC en situation réelle, en particulier les cyberattaques, ainsi que les difficultés rencontrées lors de l'activation des plans de continuité des activités de TIC et des plans de réponse et de rétablissement des TIC, de même que les informations pertinentes échangées avec les contreparties et évaluées lors des contrôles prudentiels, sont dûment intégrés, de manière continue, dans le processus d'évaluation du risque lié aux TIC. Ces constatations permettent d'effectuer un examen approprié des composantes pertinentes du cadre de gestion du risque lié aux TIC visé à l'article 6, paragraphe 1.

« Observation »: Standard

13.4 — - Non évaluée

Progression: Terminé

Les entités financières contrôlent l'efficacité de la mise en œuvre de leur stratégie de résilience opérationnelle numérique définie à l'article 6, paragraphe 8. Elles retracent l'évolution du risque lié aux TIC dans le temps, analysent la fréquence, les types, l'ampleur et l'évolution des incidents liés aux TIC, en particulier les cyberattaques et leurs caractéristiques, afin de cerner le niveau d'exposition au risque lié aux TIC, en particulier en ce qui concerne les fonctions critiques ou importantes, et de renforcer la maturité et la préparation des TIC de l'entité financière.

« Observation »: Aucune stratégie de résilience opérationnelle numérique présentée (voir 6.8) : son efficacité ne peut pas être suivie.

13.5 — - Non évaluée

Progression: Terminé

Les membres de l'encadrement supérieur responsables des TIC rendent compte au moins une fois par an, à l'organe de direction, des constatations visées au paragraphe 3 et formulent des recommandations.

« Observation »: Standard

13.6 — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

Les entités financières élaborent des programmes de sensibilisation à la sécurité des TIC et des formations à la résilience opérationnelle numérique qu'elles intègrent à leurs programmes de formation du personnel sous forme de modules obligatoires. Ces programmes et formations sont destinés à tous les employés et aux membres de la direction et présentent un niveau de complexité proportionné à leurs fonctions. Le cas échéant, les entités financières incluent également les prestataires tiers de services TIC dans leurs programmes de formation pertinents conformément à l'article 30, paragraphe 2, point i).

« Observation »: Les formations n'atteignent pas la direction : aucun membre du directoire formé depuis 2024 (C3). Programme du personnel non examiné.

« Mesures appliquées »: Former les membres du directoire au risque TIC

13.7 — - Non évaluée

Progression: Terminé

Les entités financières, autres que les microentreprises, assurent un suivi continu des évolutions technologiques pertinentes, notamment en vue de déterminer l'incidence que le déploiement de ces nouvelles technologies pourrait avoir sur les exigences en matière de sécurité des TIC et la résilience opérationnelle numérique. Elles se tiennent informées des processus de gestion du risque lié aux TIC les plus récents, afin de lutter efficacement contre les formes actuelles ou émergentes de cyberattaques.

14.1 — - Non évaluée

Progression: Terminé

Aux fins du cadre de gestion du risque lié aux TIC visé à l'article 6, paragraphe 1, les entités financières mettent en place des plans de communication en situation de crise qui favorisent une divulgation responsable, au minimum, des incidents majeurs liés aux TIC ou des vulnérabilités majeures aux clients et aux contreparties ainsi qu'au public, le cas échéant.

« Observation »: Standard

14.2 — - Non évaluée

Progression: Terminé

Aux fins du cadre de gestion du risque lié aux TIC, les entités financières mettent en œuvre des politiques de communication à l'intention des membres du personnel interne et des parties prenantes externes. Les politiques de communication à l'intention du personnel tiennent compte de la nécessité d'établir une distinction entre le personnel participant à la gestion du risque lié aux TIC, en particulier le personnel responsable de la réponse et du rétablissement, et le personnel qui doit être informé.

« Observation »: Standard

14.3 — - Non évaluée

Progression: Terminé

Au moins une personne au sein de l'entité financière est chargée de mettre en œuvre la stratégie de communication concernant les incidents liés aux TIC et remplit la fonction d'information du public et des médias à cette fin.

« Observation »: Standard

16.1 — - Non applicable

Progression: Terminé

Les articles 5 à 15 du présent règlement ne s'appliquent pas aux petites entreprises d'investissement non interconnectées et aux établissements de paiement exemptés en vertu de la directive (UE) 2015/2366; aux établissements exemptés en vertu de la directive 2013/36/UE pour lesquels les États membres ont décidé de ne pas appliquer l'option visée à l'article 2, paragraphe 4, du présent règlement; aux établissements de monnaie électronique exemptés en vertu de la directive 2009/110/CE; et aux petites institutions de retraite professionnelle.

« Observation »: Cadre simplifié réservé aux petites entités listées au 16.1 ; la banque, établissement de crédit, relève des articles 5 à 15.

- — - Non applicable

Progression: Terminé

Sans préjudice du premier alinéa, les entités énumérées au premier alinéa doivent:

« Observation »: Cadre simplifié réservé aux petites entités listées au 16.1 ; la banque, établissement de crédit, relève des articles 5 à 15.

16.1.a — - Non applicable

Progression: Terminé

mettre en place et maintenir un cadre de gestion du risque lié aux TIC solide et documenté qui détaille les mécanismes et les mesures permettant une gestion rapide, efficace et complète du risque lié aux TIC, y compris en ce qui concerne la protection des composantes et infrastructures physiques pertinentes;

« Observation »: Cadre simplifié réservé aux petites entités listées au 16.1 ; la banque, établissement de crédit, relève des articles 5 à 15.

16.1.b — - Non applicable

Progression: Terminé

surveiller en permanence la sécurité et le fonctionnement de tous les systèmes de TIC;

« Observation »: Cadre simplifié réservé aux petites entités listées au 16.1 ; la banque, établissement de crédit, relève des articles 5 à 15.

16.1.c — - Non applicable

Progression: Terminé

réduire au minimum l'incidence du risque lié aux TIC grâce à l'utilisation de systèmes, protocoles et outils de TIC solides, résilients et actualisés, aptes à soutenir l'exercice de leurs activités et la fourniture de services et à protéger de manière adéquate la disponibilité, l'authenticité, l'intégrité et la confidentialité des données dans le réseau et les systèmes d'information;

« Observation »: Cadre simplifié réservé aux petites entités listées au 16.1 ; la banque, établissement de crédit, relève des articles 5 à 15.

16.1.d — - Non applicable

Progression: Terminé

permettre d'identifier et de détecter rapidement les sources de risque et les anomalies liés aux TIC dans le réseau et les systèmes d'information et de traiter rapidement les incidents liés aux TIC;

« Observation »: Cadre simplifié réservé aux petites entités listées au 16.1 ; la banque, établissement de crédit, relève des articles 5 à 15.

16.1.e — - Non applicable

Progression: Terminé

recenser les principales dépendances vis-à-vis des prestataires tiers de services TIC;

« Observation »: Cadre simplifié réservé aux petites entités listées au 16.1 ; la banque, établissement de crédit, relève des articles 5 à 15.

16.1.f — - Non applicable

Progression: Terminé

assurer la continuité des fonctions critiques ou importantes, au moyen de plans de continuité des activités et de mesures de réponse et de rétablissement, qui comprennent au moins des mesures de sauvegarde et de restauration;

« Observation »: Cadre simplifié réservé aux petites entités listées au 16.1 ; la banque, établissement de crédit, relève des articles 5 à 15.

16.1.g — - Non applicable

Progression: Terminé

tester régulièrement les plans et mesures visés au point f), ainsi que l'efficacité des contrôles mis en œuvre conformément aux points a) et c);

« Observation »: Cadre simplifié réservé aux petites entités listées au 16.1 ; la banque, établissement de crédit, relève des articles 5 à 15.

16.1.h — - Non applicable

Progression: Terminé

mettre en œuvre, le cas échéant, les conclusions opérationnelles pertinentes résultant des tests visés au point g) et de l'analyse post-incident dans le processus d'évaluation du risque lié aux TIC et élaborer, en fonction des besoins et du profil de risque lié aux TIC, des programmes de sensibilisation en matière de sécurité des TIC et de formation à la résilience opérationnelle numérique à l'intention du personnel et de la direction.

« Observation »: Cadre simplifié réservé aux petites entités listées au 16.1 ; la banque, établissement de crédit, relève des articles 5 à 15.

16.2 — - Non applicable

Progression: Terminé

Le cadre de gestion du risque lié aux TIC visé au paragraphe 1, deuxième alinéa, point a), est documenté et réexaminé périodiquement et en cas d'incidents majeurs liés aux TIC conformément aux instructions des autorités de surveillance. Il est amélioré en permanence sur la base des enseignements tirés de la mise en œuvre et du suivi. Un rapport sur le réexamen du cadre de gestion du risque lié aux TIC est présenté à l'autorité compétente à sa demande.

« Observation »: Cadre simplifié réservé aux petites entités listées au 16.1 ; la banque, établissement de crédit, relève des articles 5 à 15.

17.1 — - Partiellement conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

Les entités financières définissent, établissent et mettent en œuvre un processus de gestion des incidents liés aux TIC afin de détecter, de gérer et de notifier les incidents liés aux TIC.

« Observation »: Un processus de gestion des incidents existe, mais il est antérieur à DORA et n'a pas été mis à jour (C6).

« Mesures appliquées »: Aligner la classification des incidents sur les critères réglementaires et tester la notification à l'ACPR

17.2 — - Non évaluée

Progression: Terminé

Les entités financières enregistrent tous les incidents liés aux TIC et les cybermenaces importantes. Les entités financières mettent en place des procédures et des processus adéquats pour assurer une surveillance, un traitement et un suivi cohérents et intégrés des incidents liés aux TIC, pour veiller à ce que les causes originelles soient identifiées et documentées et qu'il y soit remédié pour éviter que de tels incidents ne se produisent.

« Observation »: Le SOC enregistre les incidents ; l'analyse et le traitement des causes racines n'ont pas été examinés. Preuve non fournie à la date de clôture.

17.3 — - Non applicable

Progression: Terminé

Le processus de gestion des incidents liés aux TIC visé au paragraphe 1:

« Observation »: Phrase d'introduction : l'évaluation porte sur les points a à f.

17.3.a — - Non évaluée

Progression: Terminé

met en place des indicateurs d'alerte précoce;

« Observation »: Standard

17.3.b — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité majeure

instaure des procédures destinées à identifier, suivre, consigner, catégoriser et classer les incidents liés aux TIC en fonction de leur priorité et de leur gravité et en fonction de la criticité des services touchés, conformément aux critères fixés à l'article 18, paragraphe 1;

« Observation »: La classification repose sur une grille interne antérieure à DORA, sans les critères de l'article 18 (C6).

« Mesures appliquées »: Aligner la classification des incidents sur les critères réglementaires et tester la notification à l'ACPR

17.3.c — - Non évaluée

Progression: Terminé

attribue les rôles et les responsabilités qui doivent être activés pour différents types et scénarios d'incidents liés aux TIC;

« Observation »: Standard

17.3.d — - Non évaluée

Progression: Terminé

établit des plans pour la communication à l'intention du personnel, des parties prenantes externes et des médias, conformément à l'article 14, et pour la notification aux clients, les procédures internes de remontée des informations, y compris les plaintes des clients liées aux TIC, ainsi que pour la fourniture d'informations aux entités financières qui agissent en tant que contreparties, le cas échéant;

« Observation »: Standard

17.3.e — - Non évaluée

Progression: Terminé

permet de notifier au minimum les incidents majeurs liés aux TIC aux membres de la direction concernés et de communiquer à l'organe de direction au minimum des informations sur les incidents majeurs liés aux TIC, expliquant leurs incidences, la réponse à leur apporter et les contrôles supplémentaires à mettre en place à la suite de tels incidents;

« Observation »: Standard

17.3.f — - Partiellement conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

définit des procédures de réponse en cas d'incident lié aux TIC, afin d'en atténuer les effets et de garantir que les services redeviennent opérationnels et sécurisés en temps utile.

« Observation »: Réponse aux incidents assurée par le SOC, mais procédures non alignées sur DORA (C6).

« Mesures appliquées »: Aligner la classification des incidents sur les critères réglementaires et tester la notification à l'ACPR

18.1 — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité majeure

Les entités financières classent les incidents liés aux TIC et déterminent leur incidence sur la base des critères suivants:

« Observation »: La grille interne de classification est antérieure à DORA et n'applique pas les critères réglementaires (C6).

« Mesures appliquées »: Aligner la classification des incidents sur les critères réglementaires et tester la notification à l'ACPR

18.1.a — - Non évaluée

Progression: Terminé

le nombre et/ou l'importance des clients ou des contreparties financières touchés et, le cas échéant, le volume ou le nombre de transactions touchées par l'incident lié aux TIC, et si cet incident a porté atteinte à la réputation;

« Observation »: Grille interne non confrontée critère par critère ; voir 18.1.

18.1.b — - Non évaluée

Progression: Terminé

la durée de l'incident lié aux TIC, y compris les interruptions de service;

« Observation »: Grille interne non confrontée critère par critère ; voir 18.1.

18.1.c — - Non évaluée

Progression: Terminé

la répartition géographique en ce qui concerne les zones touchées par l'incident lié aux TIC, en particulier si celui-ci touche plus de deux États membres;

« Observation »: Grille interne non confrontée critère par critère ; voir 18.1.

18.1.d — - Non évaluée

Progression: Terminé

les pertes de données occasionnées par l'incident lié aux TIC en ce qui concerne la disponibilité, l'authenticité, l'intégrité ou la confidentialité des données;

« Observation »: Grille interne non confrontée critère par critère ; voir 18.1.

18.1.e — - Non évaluée

Progression: Terminé

la criticité des services touchés, y compris les transactions et les opérations de l'entité financière;

« Observation »: Grille interne non confrontée critère par critère ; voir 18.1.

18.1.f — - Non évaluée

Progression: Terminé

les conséquences économiques, en particulier les coûts et pertes directs et indirects, en termes absolus et relatifs, de l'incident lié aux TIC.

« Observation »: Grille interne non confrontée critère par critère ; voir 18.1.

18.2 — - Non évaluée

Progression: Terminé

Les entités financières classent les cybermenaces comme significatives en fonction de la criticité des services à risque, y compris des transactions et des opérations de l'entité financière, du nombre et/ou de l'importance des clients ou des contreparties financières ciblés et de la répartition géographique des zones à risque.

« Observation »: Standard

19.1 — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité majeure

Les entités financières déclarent à l'autorité compétente pertinente visée à l'article 46 les incidents majeurs liés aux TIC, conformément au paragraphe 4 du présent article.

« Observation »: Faute de classification conforme et de chaîne de notification testée, un incident majeur risque de ne pas être identifié ni déclaré à l'ACPR (C6).

« Mesures appliquées »: Aligner la classification des incidents sur les critères réglementaires et tester la notification à l'ACPR

- — - Non applicable

Progression: Terminé

Les établissements de crédit classés comme importants, conformément à l'article 6, paragraphe 4, du règlement (UE) no 1024/2013, déclarent les incidents majeurs liés aux TIC à l'autorité nationale compétente concernée désignée conformément à l'article 4 de la directive 2013/36/UE, qui transmet immédiatement cette déclaration à la BCE.

« Observation »: La banque est supervisée directement par l'ACPR : elle n'est pas un établissement « important » au sens du mécanisme de supervision unique.

« Mesures appliquées »: Aligner la classification des incidents sur les critères réglementaires et tester la notification à l'ACPR

- — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

Aux fins du premier alinéa, les entités financières établissent, après avoir recueilli et analysé toutes les informations pertinentes, la notification initiale et les rapports visés au paragraphe 4 du présent article en utilisant les modèles visés à l'article 20, et les soumettent à l'autorité compétente. S'il s'avère qu'une impossibilité technique empêche la soumission de la notification initiale au moyen du modèle, les entités financières le notifient à l'autorité compétente par d'autres moyens.

« Observation »: Les modèles réglementaires de notification ne sont pas intégrés au processus, qui est antérieur à DORA (C6).

« Mesures appliquées »: Aligner la classification des incidents sur les critères réglementaires et tester la notification à l'ACPR

- — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

La notification initiale et les rapports visés au paragraphe 4 comprennent toutes les informations nécessaires pour permettre à l'autorité compétente de déterminer l'importance de l'incident majeur lié aux TIC et d'évaluer les éventuelles incidences transfrontières.

« Observation »: Même constat : le contenu attendu des notifications n'est pas préparé (C6).

« Mesures appliquées »: Aligner la classification des incidents sur les critères réglementaires et tester la notification à l'ACPR

- — - Non applicable

Progression: Terminé

Sans préjudice de la déclaration par l'entité financière à l'autorité compétente concernée en vertu du premier alinéa, les États membres peuvent en outre décider que certaines entités financières ou toutes les entités financières fournissent également la notification initiale et chacun des rapports visés au paragraphe 4 du présent article, en utilisant les modèles visés à l'article 20, aux autorités compétentes ou aux centres de réponse aux incidents de sécurité informatique (CSIRT) désignés ou établis conformément à la directive (UE) 2022/2555.

« Observation »: Faculté laissée aux États membres, pas une obligation de la banque.

« Mesures appliquées »: Aligner la classification des incidents sur les critères réglementaires et tester la notification à l'ACPR

19.2 — - Non applicable

Progression: Terminé **Précision du résultat:** Opportunité d'amélioration

Les entités financières peuvent notifier, à titre volontaire, les cybermenaces importantes à l'autorité compétente concernée lorsqu'elles estiment que la menace est pertinente pour le système financier, les utilisateurs de services ou les clients. L'autorité compétente concernée peut communiquer ces informations à d'autres autorités compétentes conformément au paragraphe 6.

« Observation »: Notification volontaire des cybermenaces : faculté, à recommander.

- — - Non applicable

Progression: Terminé **Précision du résultat:** Opportunité d'amélioration

Les établissements de crédit classés comme importants, conformément à l'article 6, paragraphe 4, du règlement (UE) no 1024/2013, peuvent, à titre volontaire, notifier les cybermenaces importantes à l'autorité nationale compétente concernée, désignée conformément à l'article 4 de la directive 2013/36/UE, qui transmet immédiatement la notification à la BCE.

« Observation »: Notification volontaire des cybermenaces : faculté, à recommander.

- — - Non applicable

Progression: Terminé **Précision du résultat:** Opportunité d'amélioration

Les États membres peuvent décider que les entités financières qui, à titre volontaire, notifient conformément au premier alinéa peuvent également transmettre cette notification aux CSIRT désignés ou établis conformément à la directive (UE) 2022/2555.

« Observation »: Notification volontaire des cybermenaces : faculté, à recommander.

19.3 — - Non évaluée

Progression: Terminé

Lorsqu'un incident majeur lié aux TIC survient et a une incidence sur les intérêts financiers des clients, les entités financières informent leurs clients de cet incident majeur lié aux TIC et des mesures qui ont été prises pour atténuer les effets préjudiciables de cet incident sans retard injustifié, dès qu'elles en ont connaissance.

« Observation »: Standard

- — - Non évaluée

Progression: Terminé

En cas de cybermenace importante, les entités financières informent, le cas échéant, leurs clients susceptibles d'être affectés de toute mesure de protection appropriée que ces derniers pourraient envisager de prendre.

« Observation »: Standard

19.4 — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité majeure

Les entités financières soumettent, dans les délais à fixer conformément à l'article 20, premier alinéa, point a) ii), à l'autorité compétente concernée les éléments suivants:

« Observation »: La chaîne de notification à l'ACPR n'a jamais été testée : les délais réglementaires ne sont pas maîtrisés (C6).

« Mesures appliquées »: Aligner la classification des incidents sur les critères réglementaires et tester la notification à l'ACPR

19.4.a — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

une notification initiale;

« Observation »: Procédure de notification initiale, intermédiaire et finale non testée ; voir 19.4.

« Mesures appliquées »: Aligner la classification des incidents sur les critères réglementaires et tester la notification à l'ACPR

19.4.b — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

un rapport intermédiaire après la notification initiale visée au point a), dès que la situation de l'incident initial a sensiblement changé ou que le traitement de l'incident majeur lié aux TIC a changé sur la base des nouvelles informations disponibles, suivi, le cas échéant, de notifications actualisées chaque fois qu'une mise à jour pertinente de la situation est disponible, ainsi que sur demande spécifique de l'autorité compétente;

« Observation »: Procédure de notification initiale, intermédiaire et finale non testée ; voir 19.4.

« Mesures appliquées »: Aligner la classification des incidents sur les critères réglementaires et tester la notification à l'ACPR

19.4.c — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

un rapport final, lorsque l'analyse des causes originelles est terminée, que des mesures d'atténuation aient déjà été mises en œuvre ou non, et lorsque les chiffres relatifs aux incidences réelles sont disponibles en lieu et place des estimations.

« Observation »: Procédure de notification initiale, intermédiaire et finale non testée ; voir 19.4.

« Mesures appliquées »: Aligner la classification des incidents sur les critères réglementaires et tester la notification à l'ACPR

19.5 — - Non applicable

Progression: Terminé

Les entités financières peuvent externaliser, conformément au droit sectoriel de l'Union et national, les obligations de déclaration prévues par le présent article à un prestataire tiers de services. Dans le cas d'une telle externalisation, l'entité financière reste pleinement responsable du respect des exigences en matière de déclaration des incidents.

« Observation »: Faculté d'externaliser la déclaration ; aucune externalisation constatée.

- — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité majeure

Les exigences énoncées au présent chapitre s'appliquent également aux incidents opérationnels ou de sécurité liés au paiement et aux incidents opérationnels ou de sécurité majeurs liés au paiement lorsqu'ils concernent des établissements de crédit, des établissements de paiement, des prestataires de services d'information sur les comptes et des établissements de monnaie électronique.

« Observation »: Les incidents liés aux paiements (FCI-02) sont soumis aux mêmes exigences et présentent les mêmes lacunes (C6).

24.1 — - Partiellement conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

Afin d'évaluer l'état de préparation en vue du traitement d'incidents liés aux TIC, de recenser les faiblesses, les défaillances et les lacunes en matière de résilience opérationnelle numérique et de mettre rapidement en œuvre des mesures correctives, les entités financières, autres que les microentreprises, établissent, maintiennent et réexaminent, en tenant compte des critères énoncés à l'article 4, paragraphe 2, un programme solide et complet de tests de résilience opérationnelle numérique, qui fait partie intégrante du cadre de gestion du risque lié aux TIC visé à l'article 6.

« Observation »: Des tests d'intrusion annuels existent sur l'application mobile, mais il n'y a pas de programme complet de tests de résilience (C7).

« Mesures appliquées »: Étendre le PCA, le BIA et le programme de tests aux FCI, scénario de perte de NovaCore inclus

24.2 — - Partiellement conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

Le programme de tests de résilience opérationnelle numérique comprend une série d'évaluations, de tests, de méthodologies, de pratiques et d'outils à appliquer conformément aux articles 25 et 26.

« Observation »: Le programme se limite aux tests d'intrusion ; pas de tests de scénarios, de bout en bout ou de performance.

« Mesures appliquées »: Étendre le PCA, le BIA et le programme de tests aux FCI, scénario de perte de NovaCore inclus

24.3 — - Non évaluée

Progression: Terminé

Lorsqu'elles exécutent le programme de tests de résilience opérationnelle numérique visé au paragraphe 1 du présent article, les entités financières, autres que les microentreprises, adoptent une approche fondée sur le risque tenant compte des critères énoncés à l'article 4, paragraphe 2, en prenant dûment en considération l'évolution du risque lié aux TIC, tout risque spécifique auquel l'entité financière concernée est ou pourrait être exposée, la criticité des actifs informationnels et des services fournis, ainsi que tout autre facteur que l'entité financière juge approprié.

« Observation »: Standard

24.4 — - Non évaluée

Progression: Terminé

Les entités financières, autres que les microentreprises, veillent à ce que les tests soient effectués par des parties indépendantes internes ou externes. Lorsque les tests sont effectués par un testeur interne, les entités financières leur accordent des ressources suffisantes et veillent à éviter les conflits d'intérêts pendant les phases de conception et d'exécution du test.

« Observation »: Standard

24.5 — - Non évaluée

Progression: Terminé

Les entités financières, autres que les microentreprises, définissent des procédures et des stratégies destinées à hiérarchiser, classer et résoudre tous les problèmes mis en évidence au cours des tests et élaborent des méthodes de validation interne pour veiller à ce que toutes les faiblesses, défaillances ou lacunes recensées soient entièrement corrigées.

« Observation »: Standard

24.6 — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité majeure

Les entités financières, autres que les microentreprises, veillent à soumettre, au moins une fois par an, tous les systèmes et applications de TIC qui soutiennent des fonctions critiques ou importantes à des tests appropriés.

« Observation »: Seule l'application mobile est testée chaque année ; le core banking, les paiements, l'anti-blanchiment et le reporting ne le sont pas (C7).

« Mesures appliquées »: Étendre le PCA, le BIA et le programme de tests aux FCI, scénario de perte de NovaCore inclus

25.1 — - Partiellement conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

Le programme de tests de résilience opérationnelle numérique visé à l'article 24 prévoit, conformément aux critères énoncés à l'article 4, paragraphe 2, l'exécution de tests appropriés, tels que des évaluations et des analyses de vulnérabilité, des analyses de sources ouvertes, des évaluations de la sécurité des réseaux, des analyses des écarts, des examens de la sécurité physique, des questionnaires et des solutions logicielles de balayage, des examens du code source lorsque cela est possible, des tests fondés sur des scénarios, des tests de compatibilité, des tests de performance, des tests de bout en bout et des tests de pénétration.

« Observation »: Seuls des tests d'intrusion sont réalisés ; aucune preuve d'analyses de vulnérabilité, de revues de code ou de tests de scénarios.

« Mesures appliquées »: Étendre le PCA, le BIA et le programme de tests aux FCI, scénario de perte de NovaCore inclus

25.2 — - Non applicable

Progression: Terminé

Les dépositaires centraux de titres et les contreparties centrales procèdent à des évaluations de la vulnérabilité avant tout déploiement ou redéploiement d'applications et composantes d'infrastructures nouvelles ou existantes et de services TIC nouveaux ou existants qui soutiennent des fonctions critiques ou importantes de l'entité financière.

« Observation »: Visent les dépositaires centraux, les contreparties centrales et les microentreprises.

25.3 — - Non applicable

Progression: Terminé

Les microentreprises effectuent les tests visés au paragraphe 1 en combinant une approche fondée sur les risques avec une planification stratégique des tests des TIC, en tenant dûment compte de la nécessité de maintenir une approche équilibrée entre, d'une part, l'ampleur des ressources et le temps à consacrer aux tests des TIC prévus au présent article et, d'autre part, l'urgence, le type de risque, la criticité des actifs informationnels et des services fournis, ainsi que tout autre facteur pertinent, y compris la capacité de l'entité financière à prendre des risques calculés.

« Observation »: Visent les dépositaires centraux, les contreparties centrales et les microentreprises.

26.1 — - Non applicable

Progression: Terminé **Précision du résultat:** Opportunité d'amélioration

Les entités financières, autres que les entités visées à l'article 16, paragraphe 1, premier alinéa, et autres que les microentreprises, qui sont identifiées conformément au paragraphe 8, troisième alinéa, du présent article effectuent au moins tous les trois ans des tests avancés au moyen d'un test de pénétration fondé sur la menace. En fonction du profil de risque de l'entité financière et compte tenu

des circonstances opérationnelles, l'autorité compétente peut, le cas échéant, demander à l'entité financière de réduire ou d'augmenter cette fréquence.

« Observation »: Tests de pénétration fondés sur la menace : obligation réservée aux entités désignées par l'autorité ; la banque ne l'est pas (hypothèse). À anticiper.

26.2 — - Non applicable

Progression: Terminé

Chaque test de pénétration fondé sur la menace couvre plusieurs, voire la totalité, des fonctions critiques ou importantes d'une entité financière et est effectué sur des systèmes en environnement de production en direct qui soutiennent ces fonctions.

« Observation »: Tests de pénétration fondés sur la menace : obligation réservée aux entités désignées par l'autorité ; la banque ne l'est pas (hypothèse). À anticiper.

- — - Non applicable

Progression: Terminé

Les entités financières recensent tous les systèmes, processus et technologies de TIC sous-jacents pertinents qui soutiennent des fonctions critiques ou importantes et des services TIC, y compris ceux qui soutiennent des fonctions critiques ou importantes qui ont été externalisés ou sous-traités à des prestataires tiers de services TIC.

« Observation »: Tests de pénétration fondés sur la menace : obligation réservée aux entités désignées par l'autorité ; la banque ne l'est pas (hypothèse). À anticiper.

- — - Non applicable

Progression: Terminé

Les entités financières évaluent quelles fonctions critiques ou importantes doivent être couvertes par les tests de pénétration fondés sur la menace. Le résultat de cette évaluation détermine la portée précise de ces tests et est validé par les autorités compétentes.

« Observation »: Tests de pénétration fondés sur la menace : obligation réservée aux entités désignées par l'autorité ; la banque ne l'est pas (hypothèse). À anticiper.

26.3 — - Non applicable

Progression: Terminé

Lorsque des prestataires tiers de services TIC sont inclus dans le champ d'application du test de pénétration fondé sur la menace, l'entité financière prend les mesures et garanties nécessaires pour assurer la participation de ces prestataires tiers de services TIC à ce test, et conserve à tout moment l'entière responsabilité de veiller au respect du présent règlement.

« Observation »: Tests de pénétration fondés sur la menace : obligation réservée aux entités désignées par l'autorité ; la banque ne l'est pas (hypothèse). À anticiper.

26.4 — - Non applicable

Progression: Terminé

Sans préjudice du paragraphe 2, premier et deuxième alinéas, lorsque l'on peut raisonnablement s'attendre à ce que la participation d'un prestataire tiers de services TIC au test de pénétration fondé sur la menace, visée au paragraphe 3, ait une incidence négative sur la qualité ou sur la sécurité des services que le prestataire tiers de services TIC fournit à des clients qui sont des entités ne relevant pas du champ d'application du présent règlement, ou sur la confidentialité des données liées à ces services, l'entité financière et le prestataire tiers de services TIC peuvent convenir par écrit que le prestataire tiers de services TIC conclut directement des accords contractuels avec un testeur externe, aux fins de la réalisation, sous la direction d'une entité financière désignée, d'un test groupé de pénétration fondé sur la menace associant plusieurs entités financières (test groupé) auxquelles le prestataire tiers de services TIC fournit des services TIC.

« Observation »: Tests de pénétration fondés sur la menace : obligation réservée aux entités désignées par l'autorité ; la banque ne l'est pas (hypothèse). À anticiper.

- — - Non applicable

Progression: Terminé

Ce test groupé couvre la gamme pertinente de services TIC qui soutiennent des fonctions critiques ou importantes sous-traitées par les entités financières au prestataire tiers de services TIC concerné. Le test groupé est considéré comme un test de pénétration fondé sur la menace réalisé par les entités financières participant au test groupé.

« Observation »: Tests de pénétration fondés sur la menace : obligation réservée aux entités désignées par l'autorité ; la banque ne l'est pas (hypothèse). À anticiper.

- — - Non applicable

Progression: Terminé

Le nombre d'entités financières participant au test groupé est dûment calibré compte tenu de la complexité et des types de services concernés.

« Observation »: Tests de pénétration fondés sur la menace : obligation réservée aux entités désignées par l'autorité ; la banque ne l'est pas (hypothèse). À anticiper.

26.5 — - Non applicable

Progression: Terminé

Les entités financières procèdent, avec la coopération de prestataires tiers de services TIC et d'autres parties concernées, y compris les testeurs mais à l'exception des autorités compétentes, à des contrôles efficaces de la gestion des risques afin d'atténuer les risques d'incidence potentielle sur les données, de dommages aux actifs et de perturbation des fonctions, services ou opérations critiques ou importants au sein de l'entité financière elle-même, de ses contreparties ou du secteur financier.

« Observation »: Tests de pénétration fondés sur la menace : obligation réservée aux entités désignées par l'autorité ; la banque ne l'est pas (hypothèse). À anticiper.

26.6 — - Non applicable

Progression: Terminé

À l'issue du test, une fois que les rapports et les plans de mesures correctives ont été approuvés, l'entité financière et, s'il y a lieu, les testeurs externes fournissent à l'autorité, désignée conformément au paragraphe 9 ou 10, une synthèse des conclusions pertinentes, les plans de mesures correctives et la documentation démontrant que le test de pénétration fondé sur la menace a été effectué conformément aux exigences.

« Observation »: Tests de pénétration fondés sur la menace : obligation réservée aux entités désignées par l'autorité ; la banque ne l'est pas (hypothèse). À anticiper.

26.7 — - Non applicable

Progression: Terminé

Les autorités fournissent aux entités financières une attestation qui confirme que le test a été effectué conformément aux exigences, comme prouvé dans la documentation, afin de permettre la reconnaissance mutuelle des tests de pénétration fondés sur la menace entre les autorités compétentes. L'entité financière notifie à l'autorité compétente concernée l'attestation, la synthèse des conclusions pertinentes et les plans de mesures correctives.

« Observation »: Tests de pénétration fondés sur la menace : obligation réservée aux entités désignées par l'autorité ; la banque ne l'est pas (hypothèse). À anticiper.

- — - Non applicable

Progression: Terminé

Sans préjudice de ladite attestation, les entités financières restent à tout moment pleinement responsables de l'incidence des tests visée au paragraphe 4.

« Observation »: Tests de pénétration fondés sur la menace : obligation réservée aux entités désignées par l'autorité ; la banque ne l'est pas (hypothèse). À anticiper.

26.8 — - Non applicable

Progression: Terminé

Pour réaliser les tests de pénétration fondés sur la menace, les entités financières font appel à des testeurs, conformément à l'article 27. Lorsque des entités financières ont recours à des testeurs internes aux fins de la réalisation de ces tests, elles engagent un testeur externe tous les trois tests.

« Observation »: Tests de pénétration fondés sur la menace : obligation réservée aux entités désignées par l'autorité ; la banque ne l'est pas (hypothèse). À anticiper.

- — - Non applicable

Progression: Terminé

Les établissements de crédit qui sont classés comme importants conformément à l'article 6, paragraphe 4, du règlement (UE) no 1024/2013 ont uniquement recours à des testeurs externes conformément à l'article 27, paragraphe 1, points a) à e).

« Observation »: Tests de pénétration fondés sur la menace : obligation réservée aux entités désignées par l'autorité ; la banque ne l'est pas (hypothèse). À anticiper.

27.1 — - Non applicable

Progression: Terminé

Afin de réaliser des tests de pénétration fondés sur la menace, les entités financières ont uniquement recours à des testeurs qui:

« Observation »: Exigences sur les testeurs de ces mêmes tests ; sans objet en l'absence de désignation.

27.1.a — - Non applicable

Progression: Terminé

possèdent l'aptitude et la réputation les plus élevées;

« Observation »: Exigences sur les testeurs de ces mêmes tests ; sans objet en l'absence de désignation.

27.1.b — - Non applicable

Progression: Terminé

possèdent des capacités techniques et organisationnelles et justifient d'une expertise spécifique en matière de renseignement sur les menaces, de tests de pénétration et de tests en mode red team;

« Observation »: Exigences sur les testeurs de ces mêmes tests ; sans objet en l'absence de désignation.

27.1.c — - Non applicable

Progression: Terminé

sont certifiés par un organisme d'accréditation dans un État membre ou adhèrent à des codes de conduite ou des cadres éthiques formels;

« Observation »: Exigences sur les testeurs de ces mêmes tests ; sans objet en l'absence de désignation.

27.1.d — - Non applicable

Progression: Terminé

fournissent une assurance indépendante ou un rapport d'audit ayant trait à la bonne gestion des risques associés à la réalisation de tests de pénétration fondés sur la menace, y compris la protection adéquate des informations confidentielles de l'entité financière et la couverture des risques opérationnels de l'entité financière;

« Observation »: Exigences sur les testeurs de ces mêmes tests ; sans objet en l'absence de désignation.

27.1.e — - Non applicable

Progression: Terminé

sont dûment et entièrement couverts par les assurances de responsabilité civile professionnelle pertinentes, y compris contre les risques de mauvaise conduite et de négligence.

« Observation »: Exigences sur les testeurs de ces mêmes tests ; sans objet en l'absence de désignation.

27.2 — - Non applicable

Progression: Terminé

Lorsqu'elles ont recours à des testeurs internes, les entités financières veillent à ce que, outre les exigences du paragraphe 1, les conditions suivantes soient remplies:

« Observation »: Exigences sur les testeurs de ces mêmes tests ; sans objet en l'absence de désignation.

27.2.a — - Non applicable

Progression: Terminé

le recours à ces testeurs internes a été approuvé par l'autorité compétente concernée ou par l'autorité publique unique désignée conformément à l'article 26, paragraphes 9 et 10;

« Observation »: Exigences sur les testeurs de ces mêmes tests ; sans objet en l'absence de désignation.

27.2.b — - Non applicable

Progression: Terminé

l'autorité compétente concernée a vérifié que l'entité financière dispose des ressources suffisantes et a veillé à éviter les conflits d'intérêts pendant les phases de conception et d'exécution du test; et

« Observation »: Exigences sur les testeurs de ces mêmes tests ; sans objet en l'absence de désignation.

27.2.c — - Non applicable

Progression: Terminé

le fournisseur de renseignements sur les menaces est externe à l'entité financière.

« Observation »: Exigences sur les testeurs de ces mêmes tests ; sans objet en l'absence de désignation.

27.3 — - Non applicable

Progression: Terminé

Les entités financières veillent à ce que les contrats conclus avec des testeurs externes requièrent une gestion efficace des résultats des tests de pénétration fondés sur la menace et à ce que le traitement de données correspondant, y compris la génération, le stockage, l'agrégation, l'élaboration, le projet, le rapport, la communication ou la destruction, ne fasse pas courir de risques à l'entité financière.

« Observation »: Exigences sur les testeurs de ces mêmes tests ; sans objet en l'absence de désignation.

28.1 — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité majeure

Les entités financières gèrent les risques liés aux prestataires tiers de services TIC en tant que partie intégrante du risque lié aux TIC dans leur cadre de gestion du risque lié aux TIC visé à l'article 6, paragraphe 1, et conformément aux principes suivants:

« Observation »: Le risque lié aux prestataires TIC n'est pas intégré au cadre de gestion des risques : registre incomplet (C8), aucune stratégie de sortie (C10), aucun rôle de suivi (5.3).

« Mesures appliquées »: Désigner un responsable du suivi des prestataires TIC et adopter une stratégie relative aux prestataires

28.1.a — - Non applicable

Progression: Terminé

les entités financières qui ont conclu des accords contractuels pour l'utilisation de services TIC dans le cadre de leurs activités restent à tout moment pleinement responsables du respect et de l'exécution de toutes les obligations découlant du présent règlement et du droit applicable aux services financiers;

« Observation »: Principe juridique : la banque reste responsable quoi qu'il arrive. Ses conséquences sont évaluées aux paragraphes 28.2 à 28.8.

28.1.b — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

les entités financières gèrent les risques liés aux prestataires tiers de services TIC dans le respect du principe de proportionnalité, en tenant compte:

« Observation »: Les dépendances aux prestataires n'étaient ni classées ni évaluées selon leur criticité avant la mission.

« Mesures appliquées »: Désigner un responsable du suivi des prestataires TIC et adopter une stratégie relative aux prestataires

28.1.b.i — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

de la nature, de l'ampleur, de la complexité et de l'importance des relations de dépendance en matière de TIC,

« Observation »: Les dépendances aux prestataires n'étaient ni classées ni évaluées selon leur criticité avant la mission.

« Mesures appliquées »: Désigner un responsable du suivi des prestataires TIC et adopter une stratégie relative aux prestataires

28.1.b.ii — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

des risques découlant des accords contractuels portant sur l'utilisation de services TIC conclus avec des prestataires tiers de services TIC, compte tenu de la criticité ou de l'importance du service, du processus ou de la fonction en question, ainsi que des incidences potentielles de ces risques sur la continuité et la disponibilité des services et activités financiers, au niveau individuel et au niveau du groupe.

« Observation »: Les dépendances aux prestataires n'étaient ni classées ni évaluées selon leur criticité avant la mission.

« Mesures appliquées »: Désigner un responsable du suivi des prestataires TIC et adopter une stratégie relative aux prestataires

28.2 — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité majeure

Aux fins de leur cadre de gestion du risque lié aux TIC, les entités financières, autres que les entités visées à l'article 16, paragraphe 1, premier alinéa, et autres que les microentreprises, adoptent une stratégie en matière de risques liés aux prestataires tiers de services TIC et la réexaminent régulièrement, en tenant compte de la stratégie multi-fournisseurs visée à l'article 6, paragraphe 9, le cas échéant. La stratégie en matière de risques liés aux prestataires tiers de services TIC inclut une politique relative à l'utilisation des services TIC qui soutiennent des fonctions critiques ou importantes fournis par des prestataires tiers de services TIC et s'applique sur une base individuelle et, le cas échéant, sur une base sous-consolidée et consolidée. Sur la base d'une évaluation du profil de risque global de l'entité financière ainsi que de l'ampleur et de la complexité des services, l'organe de direction examine régulièrement les risques identifiés en ce qui concerne les accords contractuels relatifs à l'utilisation des services TIC qui soutiennent des fonctions critiques ou importantes.

« Observation »: Aucune stratégie relative aux prestataires TIC présentée ; le directoire n'examine pas ces risques (audit interne 2025).

« Mesures appliquées »: Désigner un responsable du suivi des prestataires TIC et adopter une stratégie relative aux prestataires

28.3 — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité majeure

Aux fins de leur cadre de gestion du risque lié aux TIC, les entités financières tiennent et mettent à jour, au niveau de l'entité et aux niveaux sous-consolidé et consolidé, un registre d'informations en rapport avec tous les accords contractuels portant sur l'utilisation de services TIC fournis par des prestataires tiers de services TIC.

« Observation »: Le registre d'informations ne couvre qu'environ 60 % des contrats TIC (C8).

« Mesures appliquées »: Compléter le registre d'informations à 100 % des contrats TIC

- — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

Les accords contractuels visés au premier alinéa sont dûment documentés, en opérant une distinction entre ceux qui couvrent des services TIC qui soutiennent des fonctions critiques et ceux qui ne le font pas.

« Observation »: Avec 40 % des contrats absents du registre, la distinction FCI / non-FCI n'est pas exhaustive (C8).

« Mesures appliquées »: Compléter le registre d'informations à 100 % des contrats TIC

- — - Non évaluée

Progression: Terminé

Les entités financières communiquent au moins une fois par an aux autorités compétentes le nombre de nouveaux accords relatifs à l'utilisation de services TIC, les catégories de prestataires tiers de services TIC, le type d'accords contractuels et les services et fonctions de TIC qui sont fournis.

« Observation »: Rapport annuel à l'ACPR non examiné ; avec un registre incomplet, il ne peut pas être exhaustif.

« Mesures appliquées »: Compléter le registre d'informations à 100 % des contrats TIC

- — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

Les entités financières mettent à la disposition de l'autorité compétente, si elle en fait la demande, le registre d'informations complet ou, le cas échéant, des sections spécifiques de celui-ci, ainsi que toute information jugée nécessaire pour garantir une surveillance efficace de l'entité financière.

« Observation »: Le registre ne peut pas être fourni complet à l'ACPR sur demande (C8).

« Mesures appliquées »: Compléter le registre d'informations à 100 % des contrats TIC

- — - Non évaluée

Progression: Terminé

Les entités financières informent en temps utile l'autorité compétente de tout projet d'accord contractuel portant sur l'utilisation de services TIC qui soutiennent des fonctions critiques ou importantes ainsi que lorsqu'une fonction est devenue critique ou importante.

« Observation »: Standard

« Mesures appliquées »: Compléter le registre d'informations à 100 % des contrats TIC

28.4.a — - Non évaluée

Progression: Terminé

déterminent si l'accord contractuel couvre l'utilisation de services TIC qui soutiennent une fonction critique ou importante;

« Observation »: Standard

28.4.b — - Non évaluée

Progression: Terminé

évaluent si les conditions de surveillance en matière de conclusion de contrats sont remplies;

« Observation »: Standard

28.4.c — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

identifient et évaluent tous les risques pertinents ayant trait à l'accord contractuel, y compris la possibilité que cet accord contractuel contribue à accroître le risque de concentration informatique visé à l'article 29;

« Observation »: Aucune évaluation du risque de concentration avant contractualisation (voir article 29).

« Mesures appliquées »: Rédiger les stratégies de sortie NovaCore et Stratus Cloud et analyser le risque de concentration

28.4.d — - Non évaluée

Progression: Terminé

font preuve de toute la diligence requise à l'égard des prestataires tiers de services TIC potentiels et s'assurent, tout au long des processus de sélection et d'évaluation, que les prestataires tiers de services TIC présentent les qualités requises;

« Observation »: Standard

28.4.e — - Non évaluée

Progression: Terminé

identifient et évaluent les conflits d'intérêts susceptibles de découler de l'accord contractuel.

« Observation »: Standard

28.5 — - Non évaluée

Progression: Terminé **Précision du résultat:** Observation / point sensible

Les entités financières ne peuvent conclure des accords contractuels qu'avec des prestataires tiers de services TIC qui respectent des normes adéquates en matière de sécurité de l'information. Lorsque ces accords contractuels portent sur des fonctions critiques ou importantes, les entités financières prennent en considération, avant la conclusion des accords, l'utilisation par les prestataires tiers de services TIC des normes les plus actualisées et les plus élevées en matière de sécurité de l'information.

« Observation »: Diligence sur la sécurité des prestataires non examinée ; maturité faible de Kumo Digital relevée dans l'évaluation EBIOS.

28.6 — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

Lorsqu'elles exercent leurs droits d'accès, d'inspection et d'audit à l'égard d'un prestataire tiers de services TIC, les entités financières déterminent au préalable, sur la base d'une approche fondée sur les risques, la fréquence des audits et des inspections, ainsi que les domaines qui doivent faire l'objet d'un audit, dans le respect des normes d'audit communément admises et conformément à toute instruction de surveillance relative à l'utilisation et à l'incorporation de ces normes d'audit.

« Observation »: La banque ne peut pas exercer de droit d'audit chez Kumo Digital et Veridex, faute de clause (C9).

« Mesures appliquées »: Renégocier les contrats Kumo Digital et Veridex (droit d'audit, clauses de sortie)

- — - Non évaluée

Progression: Terminé

Lorsque des accords contractuels conclus avec des prestataires tiers de services TIC impliquent un niveau élevé de complexité technique, l'entité financière vérifie que les auditeurs, qu'il s'agisse d'auditeurs internes ou externes ou d'un groupe d'auditeurs, possèdent les compétences et les connaissances requises pour réaliser efficacement les évaluations et les audits pertinents.

« Observation »: Standard

28.7.a — - Partiellement conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

le prestataire tiers de services TIC a gravement enfreint les dispositions législatives, réglementaires ou contractuelles applicables;

« Observation »: Les contrats de Kumo Digital et Veridex ne prévoient pas de clauses de sortie (C9) ; les autres contrats n'ont pas été examinés.

« Mesures appliquées »: Renégocier les contrats Kumo Digital et Veridex (droit d'audit, clauses de sortie)

28.7.b — - Partiellement conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

le suivi des risques liés aux prestataires tiers de services TIC a révélé l'existence de circonstances susceptibles d'altérer l'exécution des fonctions prévues par l'accord contractuel, y compris des changements significatifs qui affectent l'accord ou la situation du prestataire tiers de services TIC;

« Observation »: Les contrats de Kumo Digital et Veridex ne prévoient pas de clauses de sortie (C9) ; les autres contrats n'ont pas été examinés.

« Mesures appliquées »: Renégocier les contrats Kumo Digital et Veridex (droit d'audit, clauses de sortie)

28.7.c — - Partiellement conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

le prestataire tiers de services TIC présente des faiblesses avérées liées à sa gestion globale du risque lié aux TIC et, en particulier, dans la manière dont il assure la disponibilité, l'authenticité, l'intégrité et la confidentialité des données, qu'il s'agisse de données à caractère personnel ou autrement sensibles, ou de données à caractère non personnel;

« Observation »: Les contrats de Kumo Digital et Veridex ne prévoient pas de clauses de sortie (C9) ; les autres contrats n'ont pas été examinés.

« Mesures appliquées »: Renégocier les contrats Kumo Digital et Veridex (droit d'audit, clauses de sortie)

28.7.d — - Partiellement conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

l'autorité compétente ne peut plus surveiller efficacement l'entité financière en raison des conditions de l'accord contractuel en question ou des circonstances qui y sont liées.

« Observation »: Les contrats de Kumo Digital et Veridex ne prévoient pas de clauses de sortie (C9) ; les autres contrats n'ont pas été examinés.

« Mesures appliquées »: Renégocier les contrats Kumo Digital et Veridex (droit d'audit, clauses de sortie)

28.8 — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité majeure

Pour les services TIC qui soutiennent des fonctions critiques ou importantes, les entités financières mettent en place des stratégies de sortie. Les stratégies de sortie tiennent compte des risques susceptibles d'apparaître au niveau des prestataires tiers de services TIC, en particulier une éventuelle défaillance de leur part, une détérioration de la qualité des services TIC fournis, toute perturbation de l'activité due à une fourniture inappropriée ou défaillante de services TIC ou tout risque significatif découlant du déploiement approprié et continu du service TIC concerné, ou la résiliation d'accords contractuels conclus avec un prestataire tiers de services TIC dans l'une des circonstances énumérées au paragraphe 7.

« Observation »: Aucune stratégie de sortie documentée pour NovaCore ni Stratus Cloud (C10).

« Mesures appliquées »: Rédiger les stratégies de sortie NovaCore et Stratus Cloud et analyser le risque de concentration

28.8.a — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

perturber leurs activités;

« Observation »: Sans stratégie de sortie (voir 28.8), il n'existe ni plan de transition, ni solution alternative, ni test.

« Mesures appliquées »: Rédiger les stratégies de sortie NovaCore et Stratus Cloud et analyser le risque de concentration

28.8.b — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

restreindre le respect des exigences réglementaires;

« Observation »: Sans stratégie de sortie (voir 28.8), il n'existe ni plan de transition, ni solution alternative, ni test.

« Mesures appliquées »: Rédiger les stratégies de sortie NovaCore et Stratus Cloud et analyser le risque de concentration

28.8.c — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

porter atteinte à la continuité et à la qualité des services fournis aux clients.

« Observation »: Sans stratégie de sortie (voir 28.8), il n'existe ni plan de transition, ni solution alternative, ni test.

« Mesures appliquées »: Rédiger les stratégies de sortie NovaCore et Stratus Cloud et analyser le risque de concentration

- — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

Les plans de sortie sont complets et documentés et, conformément aux critères énoncés à l'article 4, paragraphe 2, sont soumis à des tests suffisants et réexaminés périodiquement.

« Observation »: Sans stratégie de sortie (voir 28.8), il n'existe ni plan de transition, ni solution alternative, ni test.

« Mesures appliquées »: Rédiger les stratégies de sortie NovaCore et Stratus Cloud et analyser le risque de concentration

- — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

Les entités financières définissent des solutions alternatives et élaborent des plans de transition leur permettant de supprimer les services TIC visés par le contrat et les données pertinentes détenues par le prestataire tiers de services TIC, et de les transférer en toute sécurité et intégralement à des prestataires alternatifs ou de les réincorporer en interne.

« Observation »: Sans stratégie de sortie (voir 28.8), il n'existe ni plan de transition, ni solution alternative, ni test.

« Mesures appliquées »: Rédiger les stratégies de sortie NovaCore et Stratus Cloud et analyser le risque de concentration

- — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

Les entités financières disposent des mesures d'urgence qui s'imposent pour maintenir la continuité des activités au cas où les circonstances visées au premier alinéa se présenteraient.

« Observation »: Sans stratégie de sortie (voir 28.8), il n'existe ni plan de transition, ni solution alternative, ni test.

« Mesures appliquées »: Rédiger les stratégies de sortie NovaCore et Stratus Cloud et analyser le risque de concentration

29.1.a — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité majeure

la conclusion d'un contrat avec un prestataire tiers de services TIC dont les services ne sont pas facilement substituables; ou

« Observation »: Aucune analyse de substituabilité ; le core banking NovaCore n'est pas facilement remplaçable.

« Mesures appliquées »: Rédiger les stratégies de sortie NovaCore et Stratus Cloud et analyser le risque de concentration

29.1.b — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

la mise en place de plusieurs accords contractuels relatifs à la fourniture de services TIC qui soutiennent des fonctions critiques ou importantes avec le même prestataire tiers de services TIC ou avec des prestataires tiers de services TIC étroitement liés.

« Observation »: Aucune analyse de concentration ni étude de solutions alternatives.

« Mesures appliquées »: Rédiger les stratégies de sortie NovaCore et Stratus Cloud et analyser le risque de concentration

- — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

Les entités financières évaluent les avantages et les coûts des solutions alternatives, telles que le recours à différents prestataires tiers de services TIC, en tenant compte de la compatibilité éventuelle des solutions envisagées avec leurs besoins et leurs objectifs définis dans leur stratégie de résilience numérique, et de la manière de garantir cette compatibilité.

« Observation »: Aucune analyse de concentration ni étude de solutions alternatives.

« Mesures appliquées »: Rédiger les stratégies de sortie NovaCore et Stratus Cloud et analyser le risque de concentration

29.2 — - Non évaluée

Progression: Terminé **Précision du résultat:** Observation / point sensible

Lorsque les accords contractuels relatifs à l'utilisation de services TIC qui soutiennent des fonctions critiques ou importantes prévoient la possibilité qu'un prestataire tiers de services TIC sous-traite des services TIC qui soutiennent une fonction critique ou importante à d'autres prestataires tiers de services TIC, les entités financières évaluent les avantages et les risques qui peuvent découler de cette sous-traitance, en particulier dans le cas d'un sous-traitant de services TIC établi dans un pays tiers.

« Observation »: Recours éventuel à la sous-traitance non examiné ; à vérifier pour l'équipe de Kumo Digital au Maroc.

- — - Non conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

Lorsque des accords contractuels concernent des services TIC qui soutiennent des fonctions critiques ou importantes, les entités financières tiennent dûment compte des dispositions de la législation en matière d'insolvabilité qui s'appliqueraient en cas de faillite du prestataire tiers de services TIC, ainsi que de toute contrainte qui pourrait survenir relativement à la récupération urgente des données de l'entité financière.

« Observation »: La défaillance de NovaCore n'est pas anticipée (pas de stratégie de sortie, C10) ; la récupération urgente des données n'est pas garantie.

« Mesures appliquées »: Rédiger les stratégies de sortie NovaCore et Stratus Cloud et analyser le risque de concentration

- — - Non applicable

Progression: Terminé **Précision du résultat:** Observation / point sensible

Lorsque des accords contractuels relatifs à l'utilisation de services TIC qui soutiennent des fonctions critiques ou importantes sont conclus avec un prestataire tiers de services TIC établi dans un pays tiers, les entités financières tiennent également compte, en plus des considérations visées au deuxième alinéa, du respect des règles de l'Union en matière de protection des données et de l'application effective de la législation dans ce pays tiers.

« Observation »: Aucun prestataire n'est établi hors UE. Les mêmes vérifications sont recommandées pour l'activité de Kumo Digital au Maroc.

- — - Non évaluée

Progression: Terminé

Lorsque les accords contractuels relatifs à l'utilisation de services TIC qui soutiennent des fonctions critiques ou importantes prévoient une sous-traitance, les entités financières évaluent si et comment des chaînes de sous-traitance potentiellement longues ou complexes sont susceptibles de compromettre leur capacité à assurer un suivi rigoureux des fonctions visées par le contrat et la capacité de l'autorité compétente à surveiller efficacement l'entité financière à cet égard.

« Observation »: Standard

30.1 — - Non évaluée

Progression: Terminé

Les droits et obligations de l'entité financière et du prestataire tiers de services TIC sont définis clairement et consignés par écrit. L'intégralité du contrat comprend les accords de niveau de service et est consignée dans un document écrit unique qui est mis à la disposition des parties sur papier, ou dans un document sous un autre format téléchargeable, durable et accessible.

« Observation »: Standard

30.2.a — - Non évaluée

Progression: Terminé

une description claire et exhaustive de tous les services TIC et fonctions qui seront fournis par le prestataire tiers de services TIC, indiquant si la sous-traitance d'un service TIC qui soutient une fonction critique ou importante, ou de parties significatives de celle-ci, est autorisée et, le cas échéant, les conditions applicables à cette sous-traitance;

« Observation »: Standard

30.2.b — - Non évaluée

Progression: Terminé **Précision du résultat:** Observation / point sensible

les lieux, notamment les régions ou les pays, où les services TIC et fonctions visés par le contrat ou la sous-traitance seront fournis et où les données seront traitées, y compris le lieu de stockage, et l'obligation pour le prestataire tiers de services TIC d'informer au préalable l'entité financière si celui-ci envisage de changer ces lieux;

« Observation »: Vérifier que le contrat de Kumo Digital mentionne le Maroc comme lieu de fourniture du service.

30.2.c — - Non évaluée

Progression: Terminé

des dispositions sur la disponibilité, l'authenticité, l'intégrité et la confidentialité en ce qui concerne la protection des données, y compris les données à caractère personnel;

« Observation »: Standard

30.2.d — - Non évaluée

Progression: Terminé

des dispositions sur la garantie de l'accès, de la récupération et de la restitution, dans un format facilement accessible, des données à caractère personnel et autres traitées par l'entité financière en cas d'insolvabilité, de résolution, de cessation des activités du prestataire tiers de services TIC ou de résiliation des accords contractuels;

« Observation »: Standard

30.2.e — - Non évaluée

Progression: Terminé

des descriptions des niveaux de service, y compris leurs mises à jour et révisions;

« Observation »: Standard

30.2.f — - Non évaluée

Progression: Terminé

l'obligation pour le prestataire tiers de services TIC de fournir à l'entité financière, sans frais supplémentaires ou à un coût déterminé ex ante, une assistance en cas d'incident lié aux TIC en rapport avec le service TIC fourni à l'entité financière;

« Observation »: Standard

30.2.g — - Non évaluée

Progression: Terminé

l'obligation pour le prestataire tiers de services TIC de coopérer pleinement avec les autorités compétentes et les autorités de résolution de l'entité financière, y compris les personnes nommées par eux;

« Observation »: Standard

30.2.h — - Partiellement conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

les droits de résiliation et les délais de préavis minimaux correspondants pour la résiliation des accords contractuels, conformément aux attentes des autorités compétentes et des autorités de résolution;

« Observation »: Pas de droits de résiliation ni de préavis chez Kumo Digital et Veridex (C9).

« Mesures appliquées »: Renégocier les contrats Kumo Digital et Veridex (droit d'audit, clauses de sortie)

30.2.i — - Non évaluée

Progression: Terminé

les conditions de participation des prestataires tiers de services TIC aux programmes de sensibilisation à la sécurité des TIC et aux formations à la résilience opérationnelle numérique élaborés par les entités financières, conformément à l'article 13, paragraphe 6.

« Observation »: Standard

30.3.a — - Non évaluée

Progression: Terminé

des descriptions complètes des niveaux de service, y compris leurs mises à jour et révisions, assorties d'objectifs de performance quantitatifs et qualitatifs précis dans le cadre des niveaux de service convenus, afin de permettre un suivi efficace par l'entité financière des services TIC, et de prendre, sans retard injustifié, des mesures correctives appropriées lorsque les niveaux de service convenus ne sont pas atteints;

« Observation »: Standard

30.3.b — - Non évaluée

Progression: Terminé

les délais de préavis et les obligations de notification du prestataire tiers de services TIC à l'entité financière, y compris la notification de tout développement susceptible d'avoir une incidence significative sur la capacité du prestataire tiers de services TIC à fournir les services TIC qui soutiennent des fonctions critiques ou importantes de manière efficace conformément aux niveaux de service convenus;

« Observation »: Standard

30.3.c — - Non évaluée

Progression: Terminé

l'obligation pour le prestataire tiers de services TIC de mettre en œuvre et de tester des plans d'urgence et de mettre en place des mesures, des outils et des politiques de sécurité des TIC qui fournissent un niveau approprié de sécurité en vue de la prestation de services par l'entité financière, conformément à son cadre réglementaire;

« Observation »: Standard

30.3.d — - Non évaluée

Progression: Terminé

l'obligation pour le prestataire tiers de services TIC de participer et de coopérer pleinement au test de pénétration fondé sur la menace effectué par l'entité financière visé aux articles 26 et 27;

« Observation »: Standard

30.3.e — - Partiellement conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

le droit d'assurer un suivi permanent des performances du prestataire tiers de services TIC, qui comprend les éléments suivants:

« Observation »: Les contrats de Kumo Digital et Veridex, qui soutiennent des FCI, ne prévoient aucun droit d'audit (C9).

« Mesures appliquées »: Renégocier les contrats Kumo Digital et Veridex (droit d'audit, clauses de sortie)

30.3.e.i — - Partiellement conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

les droits illimités d'accès, d'inspection et d'audit par l'entité financière ou par une tierce partie désignée, et par l'autorité compétente, et le droit de prendre des copies des documents pertinents sur place s'ils sont essentiels aux activités du prestataire tiers de services TIC, dont l'exercice effectif n'est pas entravé ou limité par d'autres accords contractuels ou politiques d'exécution;

« Observation »: Les contrats de Kumo Digital et Veridex, qui soutiennent des FCI, ne prévoient aucun droit d'audit (C9).

« Mesures appliquées »: Renégocier les contrats Kumo Digital et Veridex (droit d'audit, clauses de sortie)

30.3.e.ii — - Non évaluée

Progression: Terminé

le droit de convenir d'autres niveaux d'assurance si les droits d'autres clients sont affectés;

« Observation »: Standard

30.3.e.iii — - Partiellement conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

l'obligation pour le prestataire tiers de services TIC de coopérer pleinement lors des inspections sur place et des audits effectués par les autorités compétentes, le superviseur principal, l'entité financière ou une tierce partie désignée; et

« Observation »: Même lacune (C9) : pas d'obligation de coopérer aux audits chez ces deux prestataires.

« Mesures appliquées »: Renégocier les contrats Kumo Digital et Veridex (droit d'audit, clauses de sortie)

30.3.e.iv — - Partiellement conforme

Progression: Terminé **Précision du résultat:** Non-conformité mineure

l'obligation de fournir des précisions sur la portée, les procédures à suivre et la fréquence de ces inspections et audits;

« Observation »: Même lacune (C9) : pas d'obligation de coopérer aux audits chez ces deux prestataires.

« Mesures appliquées »: Renégocier les contrats Kumo Digital et Veridex (droit d'audit, clauses de sortie)

30.3.f — - Partiellement conforme

Progression: Terminé **Précision du résultat:** Non-conformité majeure

les stratégies de sortie, en particulier la fixation d'une période de transition adéquate obligatoire:

« Observation »: Pas de clause de sortie ni de période de transition chez Kumo Digital et Veridex (C9) ; pas de stratégie de sortie NovaCore (C10).

« Mesures appliquées »: Renégocier les contrats Kumo Digital et Veridex (droit d'audit, clauses de sortie)

30.3.f.i — - Partiellement conforme

Progression: Terminé **Précision du résultat:** Non-conformité majeure

au cours de laquelle le prestataire tiers de services TIC continuera à fournir les fonctions ou services TIC concernés en vue de réduire le risque de perturbation au niveau de l'entité financière ou d'assurer sa résolution et sa restructuration efficaces;

« Observation »: Pas de clause de sortie ni de période de transition chez Kumo Digital et Veridex (C9) ; pas de stratégie de sortie NovaCore (C10).

« Mesures appliquées »: Renégocier les contrats Kumo Digital et Veridex (droit d'audit, clauses de sortie)

30.3.f.ii — - Partiellement conforme

Progression: Terminé **Précision du résultat:** Non-conformité majeure

qui permet à l'entité financière de migrer vers un autre prestataire tiers de services TIC ou de recourir à des solutions en interne adaptées à la complexité du service fourni.

« Observation »: Pas de clause de sortie ni de période de transition chez Kumo Digital et Veridex (C9) ; pas de stratégie de sortie NovaCore (C10).

« Mesures appliquées »: Renégocier les contrats Kumo Digital et Veridex (droit d'audit, clauses de sortie)

- — - Non applicable

Progression: Terminé

Par dérogation au point e), le prestataire tiers de services TIC et l'entité financière qui est une microentreprise peuvent convenir que les droits d'accès, d'inspection et d'audit de l'entité financière peuvent être délégués à une tierce partie indépendante, nommée par le prestataire tiers de services TIC, et que l'entité financière est habilitée à demander à la tierce partie, en tout temps, des informations ainsi qu'une garantie concernant la performance du prestataire tiers de services TIC.

« Observation »: Réservé aux microentreprises.

30.4 — - Non évaluée

Progression: Terminé **Précision du résultat:** Opportunité d'amélioration

Lors de la négociation d'accords contractuels, les entités financières et les prestataires tiers de services TIC envisagent l'utilisation de clauses contractuelles types élaborées par les autorités publiques pour des services particuliers.

« Observation »: Recommander l'usage des clauses contractuelles types lors des renégociations.

45.1.a — - Non applicable

Progression: Terminé **Précision du résultat:** Opportunité d'amélioration

vise à améliorer la résilience opérationnelle numérique des entités financières, notamment en les sensibilisant aux cybermenaces, en limitant ou en bloquant la capacité de propagation des cybermenaces, et en soutenant les capacités de défense, les techniques de détection des menaces et les stratégies d'atténuation ou les phases de réponse et de rétablissement;

« Observation »: Partage d'informations facultatif ; la banque n'y participe pas.

45.1.b — - Non applicable

Progression: Terminé

se déroule au sein de communautés d'entités financières de confiance;

« Observation »: Partage d'informations facultatif ; la banque n'y participe pas.

45.1.c — - Non applicable

Progression: Terminé

repose sur des dispositifs de partage des informations qui protègent la nature potentiellement sensible des informations partagées et qui sont régis par des règles de conduite dans le plein respect de la confidentialité des affaires, de la protection des données à caractère personnel conformément au règlement (UE) 2016/679 et des lignes directrices sur la politique de concurrence.

« Observation »: Partage d'informations facultatif ; la banque n'y participe pas.

45.2 — - Non applicable

Progression: Terminé

Aux fins du paragraphe 1, point c), les dispositifs de partage d'informations définissent les conditions à respecter pour y participer et, le cas échéant, précisent les modalités de participation des autorités publiques, et en quelle qualité elles peuvent être associées à ces dispositifs, les modalités de la participation des prestataires tiers de services TIC, ainsi que les aspects opérationnels de ce partage, y compris de l'utilisation de plateformes de TIC spécialisées.

« Observation »: Partage d'informations facultatif ; la banque n'y participe pas.

45.3 — - Non applicable

Progression: Terminé

Les entités financières notifient aux autorités compétentes leur participation aux dispositifs de partage d'informations visés au paragraphe 1 lors de la validation de leur adhésion ou, le cas échéant, la cessation de leur adhésion, lorsque celle-ci prend effet.

« Observation »: Partage d'informations facultatif ; la banque n'y participe pas.

64.1 — - Non applicable

Progression: Terminé

Le présent règlement entre en vigueur le vingtième jour suivant celui de sa publication au Journal officiel de l'Union européenne.
Il s'applique à partir du 17 janvier 2025.
Le présent règlement est obligatoire dans tous ses éléments et directement applicable dans tout État membre.

« Observation »: Date d'entrée en application (17 janvier 2025) : pas d'obligation à vérifier.

Engagements

Aucun engagement consigné.